DE REDES Y SISTEMAS · BASTIONADO DE REDES Y SISTEMAS · BASTION

TEMA 1: Orígenes del Bastionado (Gusano Morris (Creeper) fuerza creación del primer CSIRT.

Bastionado o hardening: Conjunto de políticas y medidas técnicas de seguridad que protegen los activos de la información mediante: *Configuraciones seguras (actualizaciones, parches, defaults) ; *Segmentación de redes; *Roles de usuario; *Elementos de protección (Firewall, EDR, IDS, WAF) con el fin de protegerse de Malware (ransomware, spyware, floatware, troyanos, gusanos, keylogguers, rootkit), Vulnerabilidades de software, Fraude, Insiders y Ataques externos. De obligado cumplimiento legal (RPGD). **Requisitos para bastionado:** ***Análisis de riesgos** (identificación de vulnerabilidades); ***Herramientas** de Autodiagnóstico (INCIBE).

Técnicas de bastionado: *Eliminación de cuentas innecesarias; *Eliminación de Contraseñas por defecto; *Elementos de protección (Firewall, EDR, IDS, WAF); *Políticas de actualizaciones de sistemas; *Deshabilitar puertos y servicios no usados; *Planes de contingencia (planes de respuesta ante incidentes); *Blindar la seguridad de las redes (roles, contraseñas, certificados).

Zero Trust: Paradigma de "cero confianza" y "mínimos privilegios" a todos los usuarios de la red. Para ello, se emplean una serie de **medidas** que lo implementan: * MFA (2FA); Control de activos (MDM); Control de Acceso a la red (NAC); Credenciales de acceso (mínimos privilegios- accesos controlados); VPN; Estrategias de ciberseguridad seguras (EDR-Cloud).

Plan Director: Es un conjunto de actividades con el objetivo de aumentar el nivel de seguridad y de reducir los riesgos. Debe incluir **medidas técnicas** como **organizativas** (Normativa ISO 27001, NIST, ENS) para proteger los procesos críticos de la organización. Estos planes se engloban dentro del ciclo de **Mejora continua**: PLANIFICAR-HACER-VERIFICAR-ACTUAR.

PRÁCTICA 1: Zero Trust, privilegios mínimos

TEMA 2: Análisis de Riesgos

Análisis de Riesgos: Se debe evaluar la situación inicial de seguridad con el fin de conocer el grado de madurez de la empresa en seguridad y cumplimiento normativo, así como evaluar la criticidad de la información con el fin de limitar el alcance de las amenazas y cumplir con determinadas normas como la ISO 27001; Existen controles de seguridad de los activos, de cumplimiento de los activos, de copias de seguridad,

Fases del análisis: *Definir Alcance; *Reconocimiento (Identificación de activos, Probabilidad de ocurrencia, Riesgos No Aceptables, Riesgos Residuales (Aceptables sin peligro)); * Mitigación de Riesgos (Eliminación del riesgo, Control de mitigación o Transferir el riesgo a un tercero (póliza o seguro)); *Establecimiento de indicadores y Verificación (ISO 27001). **El INCIBE** lo resumen en: Definir Alcance, Identificar Activos, Identificar Amenazas, Identificar Vulnerabilidades y SALVAGUARDAS, Evaluar Riesgo y Tratar Riesgo.

Principios Economía Circular: Reciclar, reutilizar, aprovechar energéticamente los residuos, políticas medioambientales. Exprimir los recursos al máximo es rentable y necesario.

Medidas técnicas de seguridad pueden ser: ***Medidas preventivas** (Firewall, IDS, SIEM, Copias de seguridad); ***Medidas reactivas** (IPS, EDR, Plan de contingencia, Virtual Patching- restringir accesos desde redes). – Catálogo de seguridad del Incibe-.

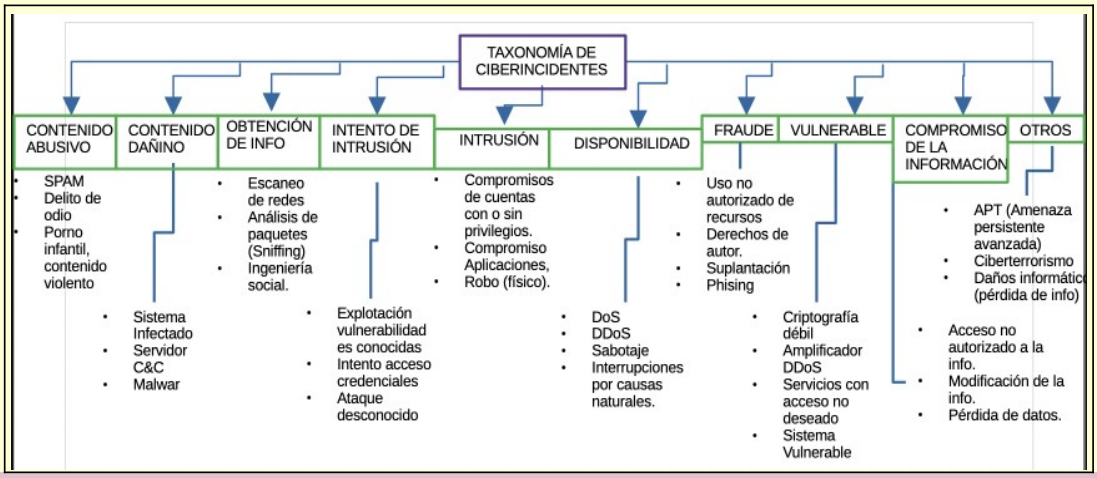
Planes de securización: *Organizativos (cumplimiento normativo – cumplimiento legal, relaciones con proveedores, concienciación y formación, políticas de codificación y contraseñas); ***Políticas técnicas** (auditorías, antimalwares, configuraciones seguras, controles de accesos, copias de seguridad, gestión de logs, actualizaciones, VPN). Las políticas de securización se aplican a las personas, procesos y tecnologías sin impedir la actividad del negocio. - Catálogo de políticas seguras para Pymes INCIBE-.

Guías de buenas prácticas: (INCIBE, CCN-CERT, ENISA, ECSO) → Guías de Ciberseguridad EU;

Estándares de securización: De obligado cumplimiento, son normas que debe implementar la organización si quiere pertenecer al estándar. Para certificar el Sistema de Gestión de la Seguridad de la Información (SGSI) deberán cumplir con el estándar de la norma ISO 27001, además de con el Esquema Nacional de Seguridad (ENS), que es un marco normativo más que un estándar, empleado por la Admin. Pública; NIST (EEUU).

Notificación de incidentes (escalado): Ventanilla única (CISO- Personas Contacto- indicadores, probabilidad e impacto, mecanismos de control) pudiendo ser: **Eventos** (alertas), **Eventos de Seguridad** (alertas de violación) o **Incidentes de Seguridad** (eventos no previstos).

Taxonomía de los ciberincidentes: INCIBE.



PRÁCTICA 2: Análisis de riesgos, Listado de activos, Amenazas, Riesgos (aceptable, no aceptable, residual), probabilidad de ocurrencia, Soluciones (recomendaciones), guía de buenas prácticas, economía circular, Conclusiones.

TEMA 3

Mecanismos de acceso: *Físicos (puertas, cajas fuertes…); ***Lógicos** (credenciales, tokens, tokens en RFID…).

Principios de control de acceso "Algo que sé, algo que soy y algo que tengo"**: *Identificación física o lógica** (algo que "sabemos" → Usuario/contraseña, Biometría (algo que "somos") o Tokens (algo que "tenemos"); ***Autenticación** (se verifica usuario); ***Autorización** (acceso a los recursos, si es autenticado → roles de usuario). Actualmente se emplea la combinación de todas ellas para MFA (2FA); **MFA** puede ser **Adaptativo** (tiene en cuenta cuestiones como ubicación, dispositivo, país) o **SSO** (Sesión única- un mail, un número).

Autenticaciones 2FA, Certificados, Tokens, Biometría, IAM

TEMA 4: Administración de credenciales

Gestores de credenciales: Administran los secretos bajo otra clave maestra. Pueden ser online, multidispositivo, generadores de contraseñas, verificadores en dos pasos e integrados en navegadores y apps (Keepass, LastPass).

Infraestructura PKI (clave pública): Es un conjunto de roles, políticas, hardware y procedimientos necesarios para gestionar (crear, administrar, distribuir, usar, almacenar) Certificados Digitales y Claves de Cifrado Públicas. Es un tipo de Cifrado Asimétrico (contiene clave pública y privada) que intenta identificar a la persona y dispositivo; **USOS:** Firma de documentos, cifrado de datos, gestión de credenciales e implementación de sistemas SSO, Operar con instituciones de manera segura (admin. Pública). Este tipo de infraestructura se utiliza como método de **Firma electrónica**, para dar fe de un documento frente a administraciones públicas.

NAC (Network Access Control) utilizado sobretodo en redes BYOD (Bring Your Own Device); también usado para dispositivos IoT o redes abiertas con acceso de terceros. Opciones Opensource: FreeNac, PacketFence.

Gestión de cuentas privilegiadas mediante: ***Cuentas de usuarios en servidores** (implementando controles sobre horarios, recursos, expiraciones, contraseñas…), ***Grupos por defecto** (de distribución sin identificador y de seguridad, con identificador y permisos); ***Administración delegada:** pretende evitar el acceso de superusuario mediante la jerarquización de los usuarios y recursos; **Técnicas** para evadir autenticaciones y permisos: PassTheHash y PassTheTicket en Active Directory. Se ha de proteger los accesos de usuarios con privilegios y bases de datos.

RADIUS (Remote Dial-In User Service): Administra las autenticaciones a la red, consta de 3 elementos: Cliente (a través de NAS), **NAS** (Network Access Server) actúa como cliente y Radius, que permite el acceso a la red. Su evolución es Diameter; es un protocolo AAA (Autenticación, Autorización y Accounting (responsabilidad)). **TABACS** en el Radius de Cisco, privativo y necesita de su equipamiento.

PRÁCTICA 4: Configuración FreeRadius

TEMA 5: Diseño de redes seguras

Conceptos básicos: ***BSSID** (Basic Service Set ID o MAC); ***ESSID** (Extended Service Set ID o Nombre AP); ***TKIP** (Protocolo de integridad de clave temporal); ***AES** (Advanced Encription Standard): ***WPS** (Wifi Protected Setup); **Modos**: Adhoc (Peer to Peer), Frames (tramas de paquetes, control (cts, rts, ack), de datos (essid, bssid, canal, vendor…);

RF-3227: Directrices para la recopilación de evidencias → PRESERVACIÓN, ADQUISICIÓN, ANÁLISIS, DOCUMENTACIÓN Y PRESENTACIÓN.

Debilidades y ataques Wifi: *Cambio de MAC; *Tipo de Cifrado (WPA2) y Encriptación (TKIP-AES); **Ataques:** *MiTM; *FakeAP; *DoS ;*Desautencicaciones.

DLP (Data Loss Prevention): Conjunto de herramientas y procesos para garantizar la integridad de los datos, que no se pierdan, dañen, roben o se utilicen inapropiadamente por accesos no autorizados. Se complementa con el **IRM (Information Resource Management)** que gestiona y monitorea la información (descargas, permisos…). Proporciona identificación de acceso a los recursos, cumplimiento normativo y segregación de roles.

VPN (Virtual Private Network) son redes privadas seguras sobre la red pública mediante un túnel IP cifrado al que solo se accede mediante certificados y no es accesible desde la red Pública. Suele implementarse a través de IPSec.

Tunneling consiste en encapsular un protocolo sobre otro creando un túnel dentro de una red, es decir, implementa paquetes de un protocolo (udp) dentro de otro protocolo (tcp) con el objetivo de transportar datos de un punto a otro sin que se pueda ver el contenido.

IPSec actúa en la capa 3 de modelo OSI (RED) por lo que protege los protocolos de capa 4 (tcp, udp) en adelante. Proporciona confidencialidad, control de acceso e integridad.

Herramientas de Monitorización: *IDS (Intrusión Detection System- Alerta pero no mitiga); ***IPS** (Intrusión Prevention System- Alerta, mitiga y registra). Pueden ser basados en Red, basados en Host o Híbridos (EDR).

Métodos de evasión: Inyecciones, fragmentación de paquetes, manipulación de paquetes, Spoofing o falsificación, Payloads, Ataques DoS. Los registros de estos dispositivos son esenciales para la investigación de incidentes de seguridad.

PRÁCTICA 5: Configuración Snort (Snort.lua/ Snort.conf), Custom /rules.

Un Firewall es un dispositivo de protección que puede ser hardware o software. Controla el tráfico de red basado en unas reglas. Para ello se parametrizan los paquetes IP y TCP, entrantes y salientes, y sus puertos, según las necesidades; IANA (Internet Assigned Number Authority) tiene un registro de puertos asociados a los protocolos. El firewall es uno de los elementos de la seguridad perimetral más importante, protegiendo, controlando y monitoreando los accesos. El ENS requiere el empleo de firewall que separe la red interna de la exterior como medida de protección.

Tipos de Firewall: *1ª Generación: Sólo actúan sobre la capa de red (3) y transporte (3) sobre los diferentes paquetes (ToS) basado en unas flags (SYN, ACK, FIN…). Se limitan a las reglas establecidas; ***2ª Generación:** Añaden capa 5 (Sesión) para el control de la red; ***3ª Generación:** Añaden la capa 7 (Aplicación). Monitoriza los puntos finales (EDR). Algunas medidas de **bastionado** asociadas al **firewall** son: ***Proteger descubrimiento de red** (Ping ICMP); ***Actualización de reglas y sistemas** (flags, puertos, apps); ***Privilegios mínimos a usuarios.**

Next Generation Firewall (NGFW): Inspeccionan todas las capas de red y aglutinan servicios como IPS o WAF convirtiéndose en el elemento más crítico de la infraestructura de red. Pueden incluir Indicadores de Comportamiento (ICOs), BigData e IA. Este tipo de servicios suelen estar integrados en la nube en plataformas FwaaS (Firewall cloud) como AWS WAF o AWS Shield.

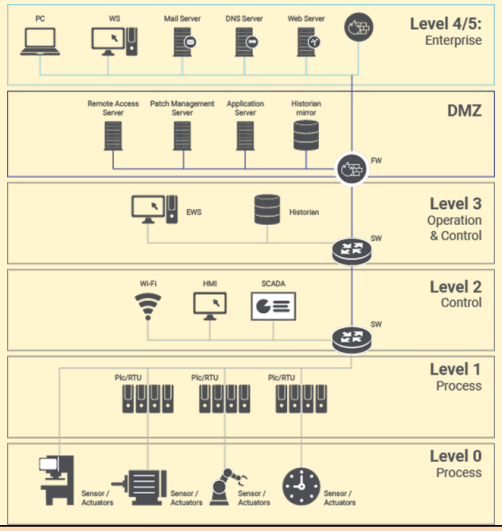
Para realizar un **Correcto Bastionado** se han de implementar **Procesos Operativos de Seguridad (POS)**.

WAF (Web Application Firewall): Firewall para servicios web. Protege de vulnerabilidades como Accesos no autorizados, XSS, SQL, manipulación de peticiones, fallos de consultas… la seguridad de los servicios web se debe revisar en todos sus ciclos de vida.

Defensa en profundidad: Establecer los elementos del sistema por capas: ***CAPA 1:** Dispositivos Perimetrales (firewall, proxu, waf, ids…); ***CAPA2**: Servidor web; ***CAPA 3**: Firewalls internos; ***CAPA 4**: Servicios asociados: BBDD, Servidores de ficheros…; ***CAPA 5**: DMZ, la zona más expuesta al exterior, con controles de acceso. La mayoría de ataques serán repelidos por apps de la capa 7 (aplicación). Estas app obedecen a un conjunto de reglas basadas en listas blancas y listas negras.

Mantenimiento: Deben existir procesos de mejora continua estipulados en una matriz de responsabilidades RACI (Responsable-Aprobador-Consultado-Informado) generada después de un incidente, que debe incluir todos los logs de los dispositivos para analizar.

Segmentación de redes: protege los accesos, segmenta la información y es monitoreada al detalle. Se basa en una defensa en profundidad por Capas, mediante la creación de VLANS y roles de acceso. El estándar es el **Modelo Purdue (IEC 62443)**.



Subnetting: Desde el punto de vista de la segmentación, se debe tener en cuenta: *Redes y dispositivos (192.168.XXX.XXX); *Controles de acceso y permisos (Roles de usuario). Se suelen usar para el filtrado de IP protocolos como ARP, TCP, DHCP…

Segmentación VLANS: Se debe tener en cuenta servicios y puertos en desuso, protocolos y contraseñas por defecto, realizando controles en cada subred del switch. Existe guías de bastionado de switches del CCN. Se deben evitar técnicas como VLAN Hopping, manipulando puertos del protocolo DTP podemos saltar de vlan.

Segmentación DMZ: Bloquear tráfico a la red interna, así como habilitar protocolos DNS y NTP. Para la arquitectura de una DMZ se suelen emplear 2 firewalls, 1 de entrada y otro de salida a la DMZ, sin interconexión entre sí.

Servicios CASB (Cloud Access Security Broker) en la nube: Tienen por objetivo controlar y gestionar los servicios en la nube mediante el acceso, monitorización y gestión de usuarios, copias de seguridad… Integran elementos de prevención como SIEM, Alertas, DNS...

TEMA 7: Configuración de dispositivos y sistemas informáticos.	**Seguridad en el puesto de trabajo** mediante EDR, IDS (software de detección a base de reglas) que suelen estar reconocidas como AntiAPT (Amenazas Persistentes Avanzadas) al incorporar IOCs actualizados monitoreando en tiempo real. **Seguridad en el correo electrónico** estableciendo listas blancas (dominios, rutas, apps), buenas prácticas (no enlaces, no ejecutables, no adjuntos); Principales protocolos: SMTP, POP3 (ambos cifrados SSL), IMAP (sin cifrar). El acceso a los servicios es HTTPS. Se deben analizar las cabeceras para deducir posibles amenazas (incrustaciones maliciosas, cabeceras de seguridad…). Para protegerse se emplea Sistemas de autenticación. **Sistemas de autenticación SMTP (Mail): *SPF** (Sender Policy Framework) que permite prevenir contra falsificaciones de remitentes, dominios, DNS, identificando a todas las IP intervinientes en un servidor SMTP; ***DKIM** (Domain Key Identified Mail) se añade PGP key para asegurar la integridad y confidencialidad. La clave se almacena en los registros DNS; ***DMARC** (Domain-based Message Authenticación Reporting & Conformance): Suma SPF y DKIM externalizando el servidor DNS de credenciales. Todos los sistemas se apoyan en el **servidor DNS** que identifica los dominios asociados a listas negras. Herramientas de **almacenamiento de logs**: Logstash, Graylog y Splunk. Recordar que hay que calcular el espacio de almacenamiento de éstos logs. **Prevenir ataques DDoS:** Entra en juego la ISP y los dispositivos Perimetrales (firewalls, ids). **Ataques comunes**: SYN Flood: No envía el paquete y el server queda esperando; UDP Flood: Inundando peticiones y el servidor desborda atendiendo a todas. Para mitigarlo es necesario distribuir la carga o servicios en al nube; *Granulado de paquetes; *Downgradear versiones de programas monitoreados. **<u>Configuración segura de equipos:</u>** Soft Actualizado, Eliminación de configuraciones y contraseñas por defecto, Eliminación de servicios y puertos en desuso, Cifrado de comunicaciones y contraseñas, Eliminación de protocolos inseguros, Control de Accesos, Control de sesiones y servicios, Revisión de registros y mantenimiento de reglas; ***Spoofing:** falsificación; ***Flooding:** inundación de peticiones. Automatización de incidentes **SOAR** (Orquestación, Automatización y Respuesta de Seguridad). Suelen ser proveedores en la nube (IBM, Cyberbit, Rapid7…). **Fases de gestión de incidentes:** PREPARACIÓN Y PREVENCIÓN- IDENTIFICACIÓN & ANÁLISIS- CONTENCIÓN – MITIGACIÓN- RECUPERACIÓN → POST-INCIDENTE (vuelta a empezar).	PRÁCTICA 7: Análisis de logs con grep, awk, y sort, geolocalización con whois, bulk domail lookup tool. Contramedidas (políticas acceso, planes de respuesta), Logs del sistema → programas usados en ataque.
TEMA 8	**Precauciones previas a instalar un SO:** *Contraseña BIOS; *Arranque seguro; *Actualización de Firmware; *Orden de arranque; *Puertos abiertos; *Dispositivos de almacenamiento. La BIOS/UEFI realiza el proceso de inicio y carga del software: Comprueba el hardware del equipo, lo inicia e inicia el sistema operativo. Es necesario proteger el acceso a la bios dado que se puede cambiar la secuencia de arranque, habilitar puertos o dispositivos (wifi, bluetooth). Quitando la pila de la CMOS (BIOS) se resetea la bios. En definitiva, la configuración segura de un equipo pasa por implementar las precauciones previas, evitando que un atacante cargue un SO en modo Live (USB-CD) deshabilitados, contraseña para no cambiar la secuencia de arranque o habilitar tarjetas de red para establecer conexiones VPN. Todos los servicios (FTP, SSH) deben estar deshabilitados o administrados. Todos los datos deben estar cifrados (bitlocker) al igual que las comunicaciones. Se debe controlar el arranque de los equipos y recopilar logs para su análisis. Esta gestión se puede hacer por medio de programas como PXE, comandando desde un PC a toda la red. Todos los datos no usados han de ser borrados.	PRÁCTICA 8: Escalada de privilegios, carpetas y archivos con permisos de escritura (ls -l, chmod 755), SUID, SGID, Sticky Bit, particiones de disco (fdisk -l), borrado de datos (wipe, dd).
TEMA 9	**Segmentación reduciendo la exposición:** *Eliminación de protocolos y servicios no usados (Telnet, SSH, RSSH, TFTP); *Hardening de procesos y configuraciones seguras de las app; *Eliminación de protocolos de red innecesarios (ICMP); *Controles de acceso y cifrado de datos y comunicaciones (Sistema de gestión de identidades PIM y de accesos privilegiados PAM (PIM-PAM)); *Sistemas de prevención frente a virus e intrusiones (IDS, IPS, EDR, Firewall); *Actualizaciones y parches automáticos (vulnerabilidades); *Sistemas de copias de seguridad (DLP) mediante **Regla 3,2,1:** 3 copias, 2 locales en medios diferentes y 1 externa almacenada online + **Plan de Recuperación Ante Desastres**. **Shadow IT** supone todas aquellas aplicaciones olvidadas, sin mantenimiento, dispositivos, software o servicios en la nube, susceptibles de ser atacados y siendo un vector de entrada. Todas las políticas de seguridad en entornos Cloud deberán estar respaldadas por una Matriz RACI (De responsabilidades) en el que se delimiten las responsabilidades entre proveedor y cliente. El ciclo de vida del software debe de acabar con la desinstalación, borrado y actualización de mecanismos de seguridad, actualización de reglas, de usuarios, bajas en los diferentes servicios (copias, redes…). En definitiva, no dejar una puerta abierta por la presencia de detalles antiguos u olvidados.	PRÁCTICA 9: Configuración segura SSH (/etc/ssh/sshd_config) y mensajes en /etc/motd

· NORMATIVA CIBERSEGURIDAD · NORMATIVA CIBERSEGURIDAD · NORMATIVA CIBERSEGURIDA	TEMA 1: CUMPLIMIENTO NORMATIVO	CUMPLIMIENTO NORMATIVO (**COMPLIANCE**): Serie de procesos, políticas y procedimientos aseguran todos los reguisitos legales, normativos y legislativos. Asegura la adopción de: *CÓDIGO ÉTICO, BUENAS PRÁCTICAS Y REQUISITOS LEGALES*. COMPROMISOS OBLIGADOS de la organización: Legislación (diferentes leyes), Obligaciones por Contrato de Terceros, Obligaciones por mandato Judicial. COMPROMISOS VOLUNTARIOS: Políticas y procedimientos, Normas y estándares, Buenas prácticas, Marcos de trabajo (Frameworks), Código ético (requiere mayor esfuerzo): Valores corporativos, principios éticos, obligaciones. El **buen gobierno corporativo** consiste en efectuar correctamente todos los cumplimientos ademas de establecer planes y modelos para el progreso futuro. (Informe anual de cumplimiento) La **ética empresarial** es el código que sigue la organización a la hora de realizar una actividad; inculca valores que recoge el código ético, las buenas prácticas y la responsabilidad social. Mejora la imagen, confianza de inversores, y de legislador. **Diligencia debida**: Acuerdos con terceros que también respeten los compromisos de la organización: Evaluación, formalización y monitorización.	PRACTICA 1: Identificar cumplimiento normativo, obligatorio y voluntario, políticas de buen gobierno, elementos de diligencia debida.	PALABRAS CLAVE: Compliance Código ético Buen gobierno ética empresarial Diligencia debida
	TEMA 2: SISTEMAS DE GESTIÓN DE CUMPLIMIENTO NORMATIVO	SISTEMA DE GESTIÓN COMPLIANCE (**SGC**): Involucra todo lo anterior. Minimiza las consecuencias por llevar a cabo actividades fuera de los márgenes de la ley. **ISO 37301** (ANTIGUA 19600): **Guía sobre compliance, SGC (cumplimiento general).** Recoge, el alcance, normativas, términos y contexto, liderazgos, planificaciones, soportes, operaciones de mantenimiento SGC y mejora contínua. PLANIFICAR, HACER, VERIFICAR, ACTUAR. Revisar epígrafes SGC. **Leyes** de mayor a menor: Constitución, Tratados Internacionales, Leyes Orgánicas y ordinarias, Decretos Legislativos y Decretos Ley, Reglamentos de gobierno, Leyes de Comunidades Autónomas, Reglamentos de comunidades Autónomas. **Jurisdicciones:** Tribunal Supremo, Audiencia Nacional, Tribunales Superiores de Justicia, Audiencias provinciales, Juzgados de primera instancia, Juzgados de lo Mercantil, Juzgados de lo Penal, Juzgados de lo contencioso-administrativo, Juzgados de lo social, Juzgados de Penitenciaria, Juzgados de Menores, Juzgados de la Violencia de la mujer, Juzgados de Paz, Tribunal Constitucional, Tribunal de Cuentas. **Leyes Nacionales:** RGPD, Ley propiedad Intelectual (LPI), Leyes de propiedad Industrial, Ley de Servicios de la Sociedad de la Información y Comercio Electrónico (LSSI-CE), Reglamento Europeo de Identificación Electrónica y Servicios de Confianza en el Mercado Interior (eIDAS). **ISO 31000:** Guía de **GESTION DE RIESGOS** (Penales, de cumplimiento normativo y de Seguridad de la Información). Identificación de riesgos, Evaluación de riesgos, y tratamiento de los Riesgos. Recoge lo mismo que la ISO 31301 **Gestión del Riesgo:** Pérdida, daño o destrucción de un Activo por materializarse una Amenaza como resultado de explotar una vulnerabilidad. Las consecuencias se miden en probabilidades e impacto tras la materialización; ***Procesos de gestión de riesgos:** I**dentificación de riesgos** (posibles amenazas), **Análisis de riesgos** (Evaluación de riesgos a nivel de Impacto y Probabilidad), y T**ratamiento de Riesgos** (decidir sobre **Evitar, Mitigar, Transferir o Aceptar** el Riesgo).	PRÁCTICA 2: Cumplimiento Normativo de la ISO 37301, Leyes que afectan, Análisis de Probabilidad e Impacto de Riesgos, Partes Interesadas,Control de riesgos, Métricas de evaluación e indicadores,	SISTEMA DE GESTIÓN COMPLIANCE (ISO 37301), SISTEMA DE GESTIÓN DE RIESGOS (ISO 31000).
	TEMA 3: LEGISLACIÓN	**Riesgos** PENALES: Incumplimiento de las Leyes. **ANÁLISIS DE RIESGO:** Impacto-Probabilidad. **UNE 19601:** Sistema de gestión compliance PENAL (**SGCP- cumplimiento Penal)**: Mide el nivel de cumplimiento y desarrolla planes para su cumplimiento reduciendo las riegos. Incluye Recursos, evaluación de riesgos, mecanismos de control, FORMACIÓN, MONITORIZACIÓN, SISTEMAS DE DENUNCIAS, sistema disciplinario. **ISO 37001**: Sistema de gestión ANTI-SOBORNO y ANTICORRUPCIÓN: Más exigente que la 19601, se basa en la evaluación de los requisitos y en los controles antisoborno: Diligencia Debida, Controles financieros, Controles no financieros y regalos, Procesos de contratación.	PRÁCTICA 3: Cumplimiento Penal, MATRIZ DE RIESGO PENAL, Impacto, Probabilidad y partes Afectadas.	Sistema de gestión de Cumplimiento Penal (ISO 19601) y Sistema de gestión de ANTIFRAUDE (ISO 37001)
	MA 4: PROTECCIÓN DE DATOS	**Datos personales**: información relativa a persona física identificada o identificable. **Datos sensibles** (raza, ideología religión…) PROHIBIDO el tratamiento (salvo consentimiento). **Legislación Vigente:** RPGD (europeo), Ley orgánica de Protección de datos (Español) **Derechos de protección**: De información (identificación del recopilador de datos y uso de los mismos), rectificación u oposición o supresión (de los datos en su base), derechos de acceso (a tus datos), derecho de Limitación del tratamiento (con terceros), de Portabilidad (para transmitirlos a otro responsable). **Figuras del tratamiento de datos**: Propietario (usuario, cliente), Responsable de tratamiento (maneja los datos) y Encargado de tratamiento (trata los datos EN NOMBRE del responsable -subcontratado-) **REQUISITOS RPGD, LOPDGDD**: Códigos de conducta: definen el nivel de cumplimiento; Registro de actividades de tratamiento; Establecer medidas de seguridad adecuadas (no obligatorias) **Brechas de datos:** se notifican en las prox 72h, a menos que sea un riesgo Alto (inmediatamente); en el ámbito privado, los responsables de tratamiento deberán notificar a la AEPD. También se deben notificar a la AEPD las transferencias internacionales de datos. **La AEPD** vela por el cumplimiento de la normativa de protección de datos y controla su aplicación. Sanciones graves (2% facturación anual), muy graves (4%), las leves (incumplimientos) hasta 40.000€ **Análisis de impacto en privacidad:** Debido a un Alto riesgo, Evaluación sistemática, Tratamiento a gran escala	PRÁCTICA 4: Privacidad, Datos Personales y Datos Sensibles, Guía de gestión de riesgo y datos personales, probabilidad de impacto y riesgos, EVALUACIÓN DE IMPACTO RELATIVO DE PROTECCIÓN DE DATOS	RPGD, AEPD y DPO

ORMATIVA CIBERSEGURIDAD · NORMATIVA CIBERSEGURIDAD · NORMATIVA CIBERSEGURIDAD	TE	**DPO**: ***Delegado de protección de datos***, vela por la protección de la información. Obligatorio en: Autoridades y organismos públicos (educación, comunicaciones, bancario, seguros, energia, publicidad y sanidad), responsables de tratamiento en actividades a gran escala, y cuando se tratan datos sensibles a gran escala. El DPO debe conocer la legislación, actuar con autonomía, notificar a los organos directos y notificarse a la AEPD, pudiendo ser interno o externo. Informa y asesora en materia de protección de datos, revisa el cumplimiento, y propone mejoras, además de ser el punto de contacto de las agencias de protección. Tiene estas responsabilidades legales anteriores, pero NO responsabilidades PENALES.		
	TEMA 5: NORMATIVA INTERNACIONAL	**Normativa Internacional:** Modelo **COSO** (EEUU, gestión ejecutiva y de cobierno), modelo **CobIT** (buenas prácticas), Controles de Servicios y Organización (**SOC2**)- Estándar de **AICPA** (Contables públicos Americanos)- Evalúan Objetivos; Controles de seguridad Críticos (Marco **CIS-CSC**); Controles de seguridad de Frameworks (**Marco SCF**); **NIST.** **NIST:** Marco de protección en ciberseguridad (EEUU) incluye 5 procesos: **IDENTIFICAR, PROTEGER, DETECTAR, RESPONDER, RECUPERAR**. Así, el **grado de madurez** pueden ser: Parcial, Informado, Repetible o Adaptativo. **ISO 27001:** SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN **(SGSI)**: Mejora continua en Madurez de ciberseguridad y asegurar la confidencialidad, integridad y disponibilidad de la información. Contiene los **EPÍGRAFES**: Contexto de la organización, Liderazgo, Planificación, Soporte, Operación, Evaluación de Desempeño, Mejora. **ISO 27002:** Complementa controles de ciberseguridad y privacidad a la 27001. Aumenta competencias en materia de Inteligencia de amenazas, configuraciones, encriptados, filtrados web, monitoreos… y todas las necesidades de la actualidad, definidas en el modelo Zero Trust. **ISO 22301**: SISTEMA DE GESTIÓN DE CONTINUIDAD DEL NEGOCIO **(SGCN)**: Evalúa los efectos de una interrupción del negocio y establece medidas para su solución. Se basa en el ciclo **DEMING: PLANIFICAR, HACER, VERIFICAR, ACTUAR**. Se basa en una serie de parámetros: Análisis de impacto de Negocio (**BIA**), Periodo máximo tolerable de interrupción (**MTPD**), Requisitos mínimos de continuidad del negocio (**MBCO**), Objetivo Punto de Recuperación (**RPO**), Objetivo de Tiempo de recuperación (**RTO**). Por tanto, un **SGCN** tiene las siguientes **FASES**: se analizan los activos, se evalúan los riesgos, se determina la estrategia de continuidad del negocio, se evalúan los recursos necesarios, y se establece el plan y los procedimientos de continuidad del negocio. **ENS: Esquema Nacional de Seguridad:** Políticas de seguridad de la información y servicios prestados por la Admin. Públicas, como Proveedores privados que prestan servicios a la Admin. Publica. Inculca proceso de ZeroTrust como privilegios mínimos, actualizaciones del sistema, Protección de la información, prevención, registros, monitorización, mejora continua. El responsable de coordinación y defensa en el ámbito de la admin.pública es CCN-CERT. **Directiva NIS (Network and Information Security Directive)** aprobada por el parlamento EU, recoge las medidas para garantizar un nivel de seguridad elevado (tanto público como privado), sentando las bases para la gestión de riesgos en ciberseguridad y notificación de incidentes de ciberseguridad. El objetivo es homogeneizar las medidas. **Reglamento NIS:** Reglamento de Seguridad de las Redes y Sistemas de Información: Desarrolla en el territorio Nacional lo establecido en la NIS. Sus funciones son: Comunicar a la Comisión Europea la lista de OSE, Transmitir los Puntos de Contacto entre estados miembros, Comunicación con CSIRT de referencia sobre incidentes perturbadores de la actividad de la empresa. La persona que encabeza estas funciones se denomina CISO, coordinando el contacto con diferentes autoridades de referencia. Elaboran políticas de seguridad para gestionar los riesgos y reducir ciberincidentes. **Agentes de Protección: CNPIC**: Centro Nacional de Protección de Infraestructuras Críticas; **CCN** (Centro Criptológico Nacional); **Autoridad Sectorial** (Operador de servicios esenciales **OSE**); **Secretaría de Estado** para los **PSD** (Proveedores de Servicios Digitales); **Delegaciones de Gobierno** (CCAA). **CSIRT:** Equipo de respuesta ante Incidentes: **CCN-CERT** (OSE, PSD- Sector público), **INCIBE-CERT** (Para sector privado); **ESPDEF-CERT** (Coopera con INCIBE en la defensa nacional). La comunicación se regula desde un **Punto de Contacto Único** y coordinador técnico. **Ley de Protección de Infraestructuras Críticas**: Lista las infraestructuras y diseña planes de prevención. Estas infraestructuras pueden ser: Servicios Esenciales, Sectores Estratégicos, Infraestructuras Críticas, criterios de criticidad. El sistema de protección es el anterior Agentes de Protección Y CSIRTS. Las empresas designadas como Sectores Críticos deberán de presentar un PSO (Plan de Seguridad del Operador- procedimientos), un PPE (Plan de Protección Específico- seguridad) y PAO (Planes de Apoyo Operativo- tácticos, elaborados por la Policía). Estas organizaciones y entidades críticas no están publicadas. El SPS (Servicio de Planes y Seguridad) coordina todos los asuntos relacionados a la seguridad integral de instalaciones críticas. **Una Declaración de Aplicabilidad** es un documento clave en el contexto de la gestión de la seguridad de la información y el cumplimiento normativo. Su propósito principal es detallar los controles de seguridad que se aplican a un sistema de gestión de seguridad de la información (SGSI) y justificar su inclusión o exclusión.	PRÁCTICA 5: Sistema de GESTION DE CONTINUIDAD DEL NEGOCIO, ESQUEMA ENS, NORMATIVA NIST, DECLARACIÓN DE APLICABILIDAD ENS, METRICAS DEL SISTEMA DE SEGURIDAD MTPD, RPO, RTO…	SGCN (ISO 2231), NIST, CSIRT, INFRAESTRUCTURAS CRÍTICAS

Haking ético: Disciplina que comprueba el nivel de madurez en materia de seguridad de un determinado activo o sistema informático. El objetivo es detectar vulnerabilidades presentes en un determinado sistema o aplicación.

Tipos de redes: Clearnet (público), DeepWeb (privado- TOR), Darkweb (privado- ilegal)

Seguridad de la información (Estratégico): Análisis de riesgos, Normativas, Plan Director (procedimientos) NO ES LO MISMO que **Seguridad Informática (IT- Táctico)**: Configuración Segura (Hardening), Técnicas de Protección(Firewall, Antivirus, IDS) & Eventos y Auditorias (Administración de Incidentes).

Pilares básicos de la Información: Confidencialidad (accesible solo por personas autorizadas), Integridad (inalterada ante incidentes) y Disponibilidad (accesible sin sufrir interrupción del servicio).

Riesgo es la pérdida, daño o destrucción de un **Activo** (Recurso de valor) como resultado de la explotación de una **Vulnerabilidad** (Debilidad de un activo).

CVSS (Common Vulnerability Scoring System): Métrica Base (características de la vulnerabilidad), Métrica Temporal (características que cambian en el tiempo), Métrica de Entorno (Características del Entorno donde fue encontrada). Da un Valor y un Vector como resultado.

Vulnerabilidades: *Dependiendo del Acceso: Locales y Remotas; *Según su dirección: De Cliente o de Servidor; * Dependiendo de su conocimiento: Zero Day (No se conoce por el fabricante o si se conoce no está resuelta), One Day (Tiene un Parche), Públicas (Explotan vulnerabilidades conocidas de versiones antiguas disponibles públicamente).

Tipos de Auditorias:* Dependiendo del enfoque: Automáticas, Manuales, Test de Intrusión, Intrusión Física, Red Team (no se informan).* **Dependiendo del Origen**: Internas (activos internos), Externas (activos expuestos a internet). ***Dependiendo la info:** Caja negra, gris o blanca.

TIPOS DE AUDITORIA DEPENDIENDO DE:

ENFOQUE
- Automáticas
- Manuales
- Test Intrusión
- Test Intrusión Física
- Red Team

ORIGEN
- **Interno:** Se auditan activos "desde dentro".
- **Externo:** Se auditan activos "desde fuera", expuestos a internet.

INFO
- **Caja Blanca:** Toda la info sobre empresa y activos disponible.
- **Caja Gris:** Solo alguna info disponible sobre los activos.
- **Caja Negra;** Ninguna info disponible. Se suele partir de un usuario.

Fases Auditoria: * Toma de Requisitos (Organizativos y Operativos) * Realización de Pruebas * Seguimiento de Pruebas * Resultados (informe ejecutivo) * Cierre de Auditoria (presentación de resultados).

FASES DE AUDITORIA

TOMA DE REQUISITOS
- **Organizativos:**
  - Alcance
  - Entorno y Enfoque
  - Usuarios
  - Personas de Contacto
- **Operativos:**
  - Permisos/ Autorizaciones
  - Accesos
  - Limitaciones Horarias
  - Limitaciones de pruebas
  - Comunicación de Incidencias
  - Avisos de inicio u otros.

REALIZACIÓN DE PRUEBAS

FASES:
1) **Reconocimiento:**
   - Activo
   - Pasivo
2) **Escaneo:**
   - Red
   - Servicios
   - Vulnerabilidades
3) **Explotación:**
   - Vector
   - Exploit
   - Metaexploit
4) **Post-Explotación**
   - Elevación de privilegios
   - Mantenimiento de acceso (persistencia)

SEGUIMIENTO DE PRUEBAS

Se estipulan las reuniones de seguimiento en caso de prever que las pruebas se extiendan en el tiempo.

REPORTE

Informa de las vulnerabilidades encontradas y propone recomendaciones.
- **Informe Ejecutivo:** Resumen de las conclusiones, métodos empleados y criticidad de las vulnerabilidades, junto con unas recomendaciones,
- **Informe Técnico:** Recoge vulnerabilidad al detalle con CVE, CVSS, Riesgos encontrados y recomendaciones.
- **Presentación de resultados:** Adscrito al informe Ejecutivo, utilizado al cierre de la auditoría.

CIERRE DE AUDITORIA

Entrega de documentación al cliente, también una **Presentación de Resultados** a alto nivel, con recomendaciones y se estipulan nuevos periodos de seguimiento de las soluciones.

Herramientas: De reconocimiento pasivo y activo, de Escaneo y Monitorización, de Explotación y de Post-explotación.

HERRAMIENTAS

RECONOCIMIENTO PASIVO -OSINT-

Extracción de info de fuentes públicas.
- **RRSS:**
  - Twitterscrapper
  - UltmateFacebook
  - Scrapedin Crawler (Linkedin)
- **APP COLABORATIVAS:**
  - Pastehunter (info sensible pastebin)
  - Githubscrapper (info sensible)
- **BUSCADORES:**
  - Google (dorking)
  - Bing
  - Shodan
  - Censys (similar a shodan)
- **WHOIS**
- **EMAIL HARVESTING:** Info sobre dominios → The Harvester.

RECONOCIMIENTO ACTIVO

Extracción directa del activo a auditar.
- **ENUMERACIÓN DNS**:
  - Dig y nslookup.
  - Dnsrecon
  - dnsenum
- **ENUMERACIÓN SMTP (MAIL):**
  - Smpt-user-enum
- **ENUMERACIÓN SNMP** (DISPOSITIVOS):
  - Onesixtyone
  - Snmpwalk
- **ENUMERACIÓN SMB:**
  - Nbtscan y enum4linux
  - Scripts nmap

ESCANEO Y MONITORIZACIÓN

Diferentes componentes de la infraestructura
- **Escaneo de Red:**
  - Whireshark/ tcpdump
  - Arpscan/ netdiscover
  - Nmap
- **Escaneo de Servicios:**
  - Nc /netcat (escucha)
  - Nmap
  - Zenmap
- **Escaneo Vulnerabilidades** (protocolos y software):
  - Nmap
  - Nessus
  - OpenVAS

EXPLOTACIÓN Y POST-EXPLOTACIÓN
- **VECTORES ESPECÍFICOS:**
  - Malware (msfvenom, shelter, goFish)
  - Credenciales por defecto (Patator, Medussa, Hydra)
  - Proxies (BurpSuite, ZapProxy, Echo Mirage)
  - Pruebas de Concepto (PoC- Exploits Públicos): Exploit-db, Github, SearchPloit
  - Frameworks: Metaexplot, CobaltStrike (C&C).
- **POST-EXPLOTACIÓN:**
  - Shellcoders (msfvenom, Meterpreter, Beacons (cobalt)
  - Escalada Privilegios: PrivesCheck, WINPeaS, LinPEAS
  - Información: Mimikatz, Keyloggers

CAPAS DE SEGURIDAD DE RED

CAPA 1	CAPA 2	CAPA 3	CAPA 4	CAPA 5	CAPA 6	CAPA 7
FÍSICA (medio de transmisión)	ENLACE DE DATOS	RED (Enrutamiento)	TRANSPORTE (Transmisión de datos)	SESIÓN (de red)	PRESENTACIÓN	APLICACIÓN

PRÁCTICA 1: Auditoría Externa: ·Toma de requisitos (Normativa general y específica), · Plan de Auditoria: Definición de la Realización de pruebas, requisitos, limitaciones y recomendaciones; · Planing (tiempos y horas); · Listado de activos a auditar; · Gestión de incidencias (canales de comunicación, personas de contacto); · Valoración de criticidad (CVSS); · Reporte y análisis de resultados (informe ejecutivo); · Cierre Auditoría (Resultados).

TEMA 2: HACKING EN ENTORNOS INALÁMBRICOS	**Estándares Wifi:** ***IEEE 802.11b/g/n** 2,4 GHz hasta 300Mbit/s con interferencias con Bluetooth 1.2, 14 canales (del 1 al 14), menor velocidad pero mayor rango; ***IEEE 802.11ac/n** 5Ghz. Mayor frecuencia, Menor Alcance, pero Más calidad, 25 Canales (del 36 al 136). * **IEEE 802.11ax** conocido como Wifi6 6GHz, mejora velocidad. El Wifi fue diseñado por un conjunto de empresas conocidas como WECA con el fin de realizar conexiones sin cables entre dispositivos. **Terminología: MAC** (Dirección de enlace de dispositivo); **BSSID** (Dirección MAC punto de acceso); **ESSID** (nombre de punto de acceso); **Handshake** ("apretón de manos" entre dispositivos); **Beacon Frames** (paquetes de información -mac-bbsid-timestamp…); **Probe Request** (Intentos de conexión de los dispositivos). **Tipos de red**: **Adhoc** (enlace entre dos dispositivos descentralizado del router); **Redes Infraestructura** (Open, WEP (de 5 a 13 carácteres), WPA2 Personal (credenciales- de 8 a 63 carácteres- TKIP- AES) y Enterprise (identidades-certificados- Radius)) **Herramientas necesarias para una auditoria:** Tarjetas wifi (modo monitor); Antenas (direccionales-omnidireccionales); Herramientas de Software: Scanners (netStumbler, Kismet), inyección de paquetes (Aireplay-ng); Cracking Contraseñas (John the Ripper, Aircrack, hashcat); Fake AP: HostAPD; Portal Cautivo: Wiphiser; Protocolo WPS: Reaver; Wardriving, Warciclyng **Modos de tarjetas: Master** (Modo infraestructura- AP); **Managed** (cliente) para conectar a AP; **Monitor** (escucha de canales); **Adhoc** (para redes multipunto). **Secuencia ataque**r: Airmon-ng- Airodump-ng- Aireplay-ng – Aircrack-ng Ataques a redes: WPA con Clientes (Handshake) y sin clientes (PMKID); WPA Enterprise (Ataques Group Policy Object, MDM o Fake AP sin CA) **Reporting:** Se informa en detalle de la estructura de la organización y las vulnerabilidades encontradas. Se apoya en el estándar CVSS para realizar el **informe ejecutivo** (resumen de conclusiones) y el **informe técnico** (detalle de conclusiones). En el cierre de auditoría, se realiza una **Presentación de resultados**, que complementa al informe ejecutivo.	PRÁCTICA 2: Análisis de redes (BOYOD, OPEN, WEB, ENTERPRISE), Análisis de pcap con wireshark y cracking con hashcat con diccionario. Poca cosa.
TEMA 3: ATAQUE Y DEFENSA EN SISTEMAS Y REDES (AMPLIACIÓN T.1)	**Fases de una auditoría**: 1.- Reconocimiento: Pasivo (Footprint- OSINT) y Activo (desde dentro) ; 2.- Escaneo Activo (Fingerprint) y Monitorización; 3.- Explotación; 4.- Post-Explotación (Persistencia). **Referirse a esquema en TEMA 1**. **Otros conceptos**: ***Exploit**: programa o script que aprovecha un defecto de seguridad en el sistema o aplicación para tomar el control (**remotos** (Server side o Client Side) o **locales** (de escalada de privilegios); ***Payload:** porción de código (carga) que se ejecuta después del exploit y realiza una serie de operaciones (**non-staged** (comando), **Staged** (código granulado más completo), **Shell** (código de ejecución completo con privilegios- **Local-bind-reverse shells**). **Metaexploit: *Módulos**: Auxiliares, Exploits, Payloads, Encoders, Post; ***Comandos:** Search, Info (help), Show (módulos disponibles), Use (usar módulo), Set (Configurar módulo), Exploit o run (Lanzar módulo) **Msfvenom:** Generar payloads. ReceiverHost (RHOSTS), LocalHost (LHOST), show options, show payloads, set payload, use exploit, jobs, sessions. **Intercepción de red:** Fake-AP, ARP Spoofing, DNS Spofing, Ettercap, Bettercap, **MiTM Proxy**: tcpproxy, stealcookies, htshijack, web-averide. **Phising:** Conjunto de técnicas que tratan de engañar a una persona, organización o servicio en que la víctima confía. Se emplea la ingeniería social para realizar fraudes bancarios o compromisos en el sistema (malware); **Tipos:** *Email phising; *Spearphising; *Whaling; *Vising; *Smishing; Pharming… Se suele emplear goPhish para crear campañas de manera automatizada, con plantillas, seguimientos,… **Elevación de privilegios:** conjunto de técnicas post-explotación que tiene como objetivo conseguir un nivel de permisos elevado en el sistema; **Tipos:** Defectos de configuración, Defectos en la gestión de autorización, Explotación de vulnerabilidades locales, Exposición de credenciales (por defecto); **Vulnerabilidades en Linux** (LinPEAS, Linenum) : Kernel, servicios, tareas "cron", superusuarios, Binarios con privilegios; **Vulnerabilidades en Windows** (PrivesCheck, WinPEAS, Watson, Seatbelt): De SO, servicios, scripts de inicio, librerias dll, archivos de registro, ejecutables (binarios)…	PRÁCTICA 3: Explotación de vulnerabilidad FTP de metaexploitable2 con Nmap y Metaexploit (nos encontramos con un cambio de Banner)
TEMA 4: USO DE METAEXPLOIT EN SISTEMAS COMPROMETIDOS	**Secuencia Post-Explotación**: Metaexploit → Post → Meterpreter → Vector de ataque → Exploit. **Conceptos: *Meterpreter:** Payload avanzado de tipo Shell para Metaexploit; ***Beacons:** Lo mismo para CobaltStrike; ***Pivoting:** Conjunto de técnicas utilizadas como "puente" entre dos sistemas comprometidos. **Tipos de ataques a contraseñas**: ***Password Guessing**: Bruteforce a SSH o FTP (Medusa, Hydra, Patator); ***Password Cracking**: Offline a los hash recopilados (John, hashcat); ***Default Passwords:** Rainbow Tables (adivinando hash de tablas almacenadas). **Pivotaje de Red (Pivoting): *Pivoting SSH**: creando un tunel cliente-servidor que sirve de Proxy (mediante Proxychains); ***Pivoting con Meterpreter**: Usando meterpreter como puente entre redes internas, añadiendo una ruta con metaexploit mediante add route; ***Pivoting HTTP:** Comprometiendo webs mediante ficheros comprometidos que se suben al servidor; ***Herramientas Pivoting:** reGeorg, Pivotnacci, **Puertas traseras:** Para conseguir Persistencia en el sistema, deberemos migrar los servicios a procesos legítimos para evitar perder la Shell; para ello emplearemos la técnica conocida como "C&C" para inyectar comandos a través de una shell inversa; Tipos de Persistencia: Handler-servidor C2 (C&C); Meterpreter: mediante módulos de persistencia o Migrate.	PRÁCTICA 4: Persistencia mediante EternalBlue (SMB), Metaexploit (persistencia registro, proceso, ejecutable, RDP (screenshare), y Cracking NTLM (Kerberos).

Arquitectura de un Aplicativo Web: 3 capas → **Controlador** (recoge los datos del usuario (url)→ **Modelo** (bases de datos de la aplicación) → **Vista** (representa los datos en HTML o Javascript generalmente), es decir, el Controlador recoge los datos del usuario para SOLICITAR los datos a la capa Modelo y se los comunica a la capa Vista para ser representados para el usuario.

Protocolo HTTP (HyperText Transfer Protocol) permite intercambiar información en la World Wide Web definiendo la sintaxis y la semántica (clientes, servidores, proxyes) para comunicarse. Cada petición es una nueva sesión y no guarda su estado anterior, por ello es necesario el uso de Cookies para mantener el estado, identificando al usuario y sesión dentro del servidor mediante las cookies (info del servidor en el dispositivo del cliente).

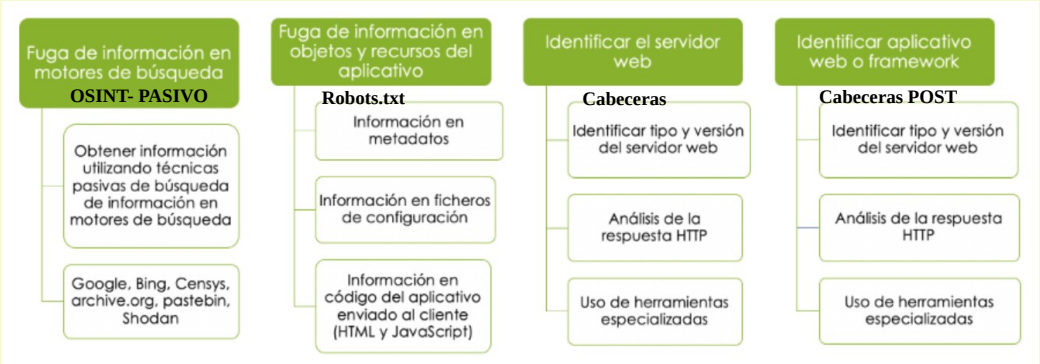
Composición HTTP: Línea de petición (método HTTP GET o POST, url y protocolo); **Headers** (cookies, user-agent, host…); **Cuerpo de la petición:** Puede estar o no incluido (info sobre la consulta como user & pass).

Estructura de una URL: protocol + subdomain + domain-name + : port + / path + query ? + & parameters = + # fragmentos: https //video.google.co. Uk: 80/videoplay?id=985938745&hl=es#01h34m43s

Respuestas de Servidor→ 1XX (Procesando) **2XX** (OK, procesado correcto) **3XX** (Redirección, server tiene que hacer otras peticiones) **4XX** (Errores en Cliente) **5XX** (Errores en servidor).

Tipos de autenticación basadas en: *Credenciales (user-pass y Digest (almacenadas en bbdd codificadas)); ***Cookies** (generado en servidor y almacenados en cliente); ***Tokens** (generado y almacenados en servidor); ***API-Keys** (Token generado en cliente y verificado en servidor); ***MFA**: (2FA- Biométrico, preguntas secretas, localizaciones, dispositivos confianza)

Pruebas de recolección de Información:

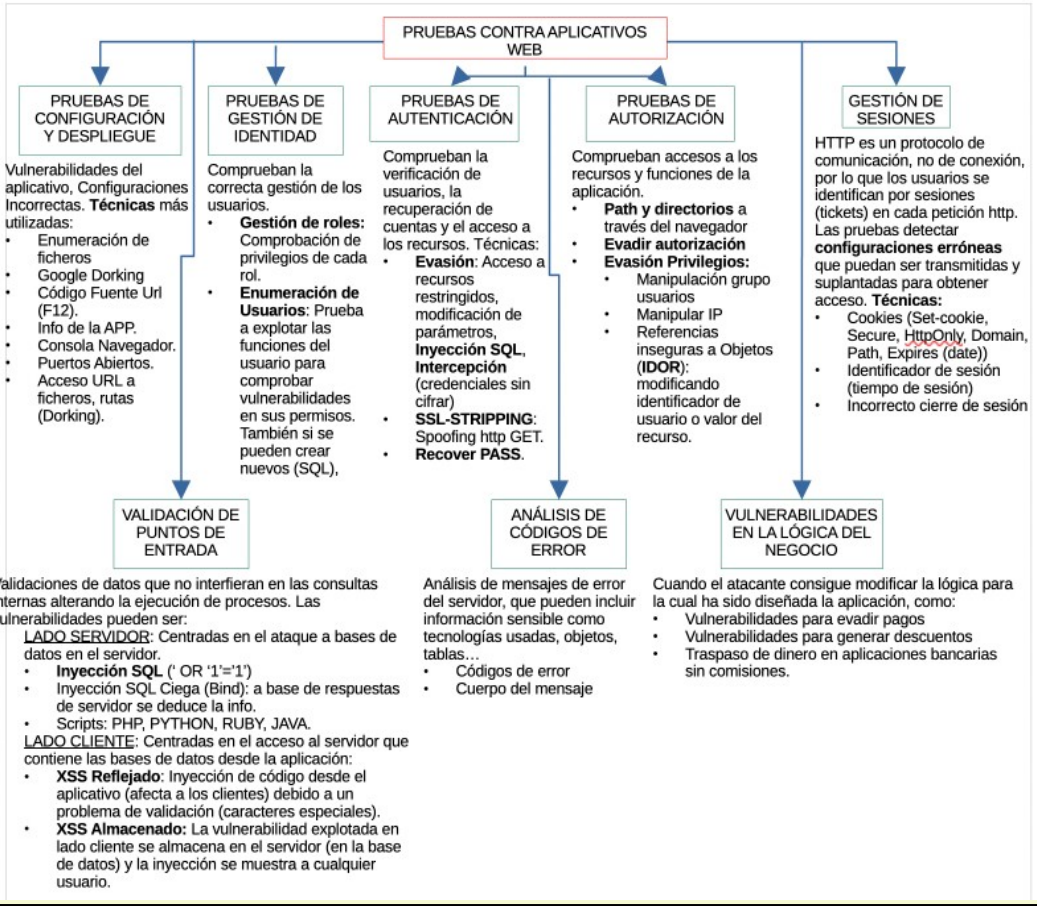


Herramientas de recolección de Información (Ampliación Esquema T.1 POST): ***Generales:** Netcat, BurpSuite, Whatweb (spidering); ***Específicas:** Nessus y OpenVAS (Vulnerabilidades), CMSMap,JoomScan, WPScan (Vulnerabilidades CMS Frameworks). También se hacen a su vez escaneos activos a los protocolos SSH, FTP, centrados en el aplicativo.

Proxys de Interceptación: Nos permiten interceptar la comunicación HTTPS entre un navegador y un aplicativo web en un servidor. El proxy genera un certificado SSL autofirmado para comunicarse entre el navegador y proxy para obtener la información del cliente, y modificarla, mientras que en el lado servidor el proxy actúa como cliente, por lo que puede descifrar el tráfico también en éste punto, dado que es el servidor el que genera el certificado; ***Herramientas:** BurpSuite, OWASP ZAP.

Mejora de aplicativos web: Guías OWASP como: *Web Security Testing Guide; *Mobile Security Testing Guide; *Zed Attack Proxy (ZAP); *TOP Ten (Mobile & Vulnerabilities); *OWASP Review Guide "Mejores prácticas en programación".

Pruebas contra aplicativos WEB: Se basan en las guías OWASP para mejorar la seguridad de aplicaciones móviles y webs.



Los **Lenguajes de programación según su ejecución** pueden ser: ***Compilados** (solo funcionan en la plataforma donde fueron construidos. El código fuente se convierte en binario durante la compilación- C ++); ***Interpretados** (funcionan en todas las plataformas de las que se disponga el intérprete usado, el código fuente es traducido en tiempo real a máquina.- PHP, Python, Java); ***Lenguaje Intermedio**: Ejecutado por las máquinas virtuales (Scala); **Según su programación** Pueden ser: ***Bajo Nivel** (nivel máquina, ensamblador, cercano a binario); ***Alto nivel** (traducidos a máquina desde un lenguaje más natural al humano). La elección depende de los requisitos técnicos del hardware y software necesarios, el tiempo de entrega y el rendimiento.

Un **programa** es un conjunto de instrucciones que ejecutan una tarea concreta, estas instrucciones se traducen a lenguaje máquina o ensamblador. Es la implementación concreta de un Algoritmo en un lenguaje específico, mientras que el algoritmo se diseña previamente para resolver la tarea.

Programar es el proceso de crear un software mediante la escritura de lenguaje (**code**) → prueba (**test**) → depuración (**debug**) → **compilación** (o interpretación) y → **mantenimiento** (maintenance) del código fuente de dicho programa; **Un Algoritmo** es una secuencia ordenada de reglas que se siguen para resolver un problema. Se utilizan para diseñar la lógica del programa, representados como diagramas de flujo, códigos o lenguaje natural.

Un **Compilador** se encarga de transformar el código fuente en binario para un tipo de plataforma y arquitectura concretos. Existen compiladores multiplataforma como Golang.

Partes de un aplicativo web: *Backend (parte de la app que se ejecuta en lado Servidor); ***Frontend** (parte de la aplicación que se ejecuta en el lado Cliente).

Funcionamiento aplicativo web: El navegador actúa de intérprete de protocolos web y lenguajes de marcado como HTML, CSS (hojas de estilo) y JavaScript (interactividad), mientras que el servidor almacena la lógica de la aplicación, BBDD y recursos, recibiendo las peticiones del cliente mediante una app y enviando las respuestas a la misma. Hoy en día se emplean APIS (Interfaz de Programación de Aplicaciones web)

APIS (Interfaz de Programación de Aplicaciones web) conjunto de reglas y protocolos que permiten la comunicación entre diferentes Softwares, diseñadas para solicitar y acceder a los datos a través de HTTP. Los datos se suelen recibir en JSON (Objetos de Java). Son accesibles desde navegadores y se ejecutan en servidores remotos, lo que las hace vulnerables a ataques DDoS, SQL Injection, XSS y CSRF (Tokens de validación).

Elementos básicos del lenguaje: Existen reglas sintácticas y semánticas, así como un léxico (símbolos, **palabras reservadas**). Se pueden incorporar comentarios, los cuales no deben incluir información sensible. Dentro del código fuente (instrucciones del programa) podemos encontrarnos una serie de **componentes: *Comandos de pre-procesamiento** (importación de módulos y librerías); ***Sentencias y expresiones*; *Declaración de variables** (contenedores de datos); ***Estructuras de Control** (bucles y condicionales); ***Funciones y métodos; *Orientación a Objetos** (clases); ***Comentarios** (notas).

Palabras reservadas: funciones específicas dentro del lenguaje que no pueden ser usadas para nada más (class, if, else, for, return…)

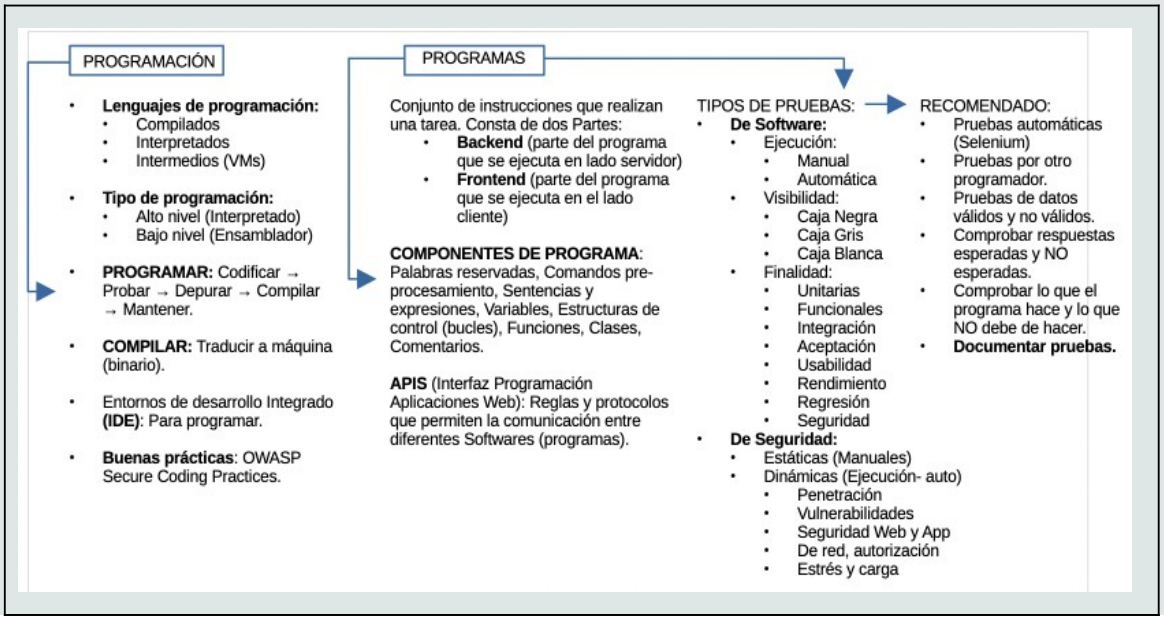
Entornos de Desarrollo Integrado (IDE- Integrated Development Environment) es un conjunto de herramientas para escribir, probar, compilar y mantener (programar). Existen varios: Visual Studio Code, Atom, Brackets… Analizar es esencial para mejorar la calidad, seguridad y eficiencia del código, ayuda a cumplir estándares y sirve para el mantenimiento; es común emplear Librerías (Funciones o rutinas predefinidas independientes de la aplicación) y Frameworks (estructuras predefinidas de código) a la hora de desarrollar programas.

Tipos de pruebas de software: ***Según su ejecución** (Manuales, Automáticas); ***Según su visibilidad** (Caja negra, gris, blanca); ***Según su finalidad**: Unitarias, Funcionales, de Integración, de Aceptación (Lado cliente UAT, Lado Negocio BAT), de Usabilidad, de Rendimiento, de Regresión, de Seguridad.

Pruebas de Seguridad: Esenciales para mitigar riesgos, protección de datos y activos críticos. Las más típicas: Pruebas de Análisis Estático (IDE- Manual); Análisis dinámico (soft en ejecución); Pruebas de penetración, de vulnerabilidades; Pruebas de seguridad de Web y Aplicaciones móviles(APIS); Pruebas de seguridad de red, autorización; Pruebas de estrés y carga.

Recomendaciones de Pruebas: Preferible automatizadas (Selenium), que no sean probadas por el propio programador, pruebas con datos válidos y no válidos, comprobando las respuestas y las no respuestas, Documentar todas las pruebas.

Buenas prácticas de programación OWASP: Secure Coding Practices → código seguro en varios lenguajes y plataformas, blindar ataques, probar en SandBox para evitar interferencias.



TEMA 2: Determinación del nivel de seguridad de las aplicaciones.

Riesgo de un software: Un agente de amenaza (threat agent) interactúa con un sistema que puede tener una vulnerabilidad que puede ser explotada para causar un impacto. Diferentes organismos plantean soluciones a las vulnerabilidades que se van detectando: NVD (NIST- BBDD de EEUU); Mitre y SANS (Mantienen las catergorías CVE); OWASP; INCIBE.

OWASP realiza ranking de riesgos (TOP 10) sobre vulnerabilidades web y aplicaciones móviles, destacando: Pérdida de Control de accesos, Fallos criptográficos, Inyecciones de código (SQL, XSS), Vulnerabilidades y fallos, Uso inadecuado de credenciales, Comunicaciones Inseguras, Autenticaciones Seguras, Criptografía Insuficiente. **Destacan 4 guías**: *Guía de desarrollo; *Guía de verificación de seguridad de la aplicación o **ASVS**; *Guía de pruebas o **WSTG** para mostrar la seguridad de una API; *Guía de seguridad de aplicaciones móviles **MASVS** (Equivalente a ASVS); Guía de perfiles de pruebas de seguridad móviles **MASTG.** Ayudan a las organizaciones al desarrollo seguro de APIS y permite la alineación con la seguridad de la información. Son usados como métricas, guías, tanto para el desarrollo como para la compra de soft. De terceros.

Los registros de vulnerabilidades más comunes es **CVE** (Common Vulnerability Exposures) o vulnerabilidades comunes conocidas en seguridad registradas por ID, Exploit, Versiones de Soft Afectadas, Soluciones (Si existen) y referencias al ataque o vulnerabilidad. Es mantenida por Mitre.

Niveles de seguridad ASVS (Seguridad de la aplicación): ***Nivel 1**: Nivel básico, debe al menos superar el **TOP TEN** de vulnerabilidades (1. Pérdida de acceso; 2. Fallos Criptográficos; 3. Inyección de código; 4. Diseño inseguro…) ; ***Nivel 2** (Standard): Recomendable para todas, sobretodo con datos sensibles (casi todas); ***Nivel 3** (Advanced): Aplicaciones críticas con datos protegidos (bancos). ASVS establece hasta 14 controles de seguridad que miden el nivel de seguridad; las aplicaciones con más nivel requieren más controles (protección de datos).

PRÁCTICA 2: Docker y DVWA, SQL Injection

TEMA 3: Detección y corrección de vulnerabilidades de aplicativos web.

Objetivos de la seguridad: *Confidencialidad (sólo disponible a quien debe tener acceso); ***Integridad** (datos correctos y confiables); ***Disponibilidad** (la información está accesible cuando se necesita); **otros objetivos** son: Resiliencia, Robustez, Trazabilidad, Autenticación, Fiabilidad.

Ciclo de vida del desarrollo de software (SDLC): PLANIFICAR → ANALIZAR → DISEÑAR → IMPLEMENTAR → PROBAR E INTEGRAR → MANTENER (Y vuelta a empezar). Se deben de definir roles y responsabilidades, formación, codificación segura, revisar las vulnerabilidades **top ten** y establecer matriz de amenazas.

Principios para desarrollar Software: Minimizar puntos de ataque (valores seguros, simplicidad del diseño, eventos de seguridad), Mínimos privilegios (no confiar en sistemas externos, validar datos de entrada y salida), Defensa en profundidad (por capas), Segmentación; para ello se recomienda un conjuntos de **Buenas Prácticas**: Validación de entradas y salidas, gestión y control de autenticaciones y autorizaciones, cifrado de datos, seguridad de las comunicaciones y los datos, configuración segura.

Un formulario está diseñado con el objetivo de que un usuario introduzca datos estructurados (nombre, apellidos, fechas…) para ser registradas y procesadas por el aplicativo web. **Es necesario que cualquier validación de entrada en el cliente se realice también en servidor**, es decir, que la vulnerabilidad está resuelta tanto en lado cliente como en lado servidor. La configuración segura es esencial para proteger los contenidos de la base de datos, eludir autenticaciones o inyectar código malicioso en la base de datos (Inyección SQL); para Proteger un formulario es necesario la verificación de entradas (caracteres especiales) y salidas, así como la iteración con la base de datos a través de scripts.

Ataques comunes a aplicativos web: *Lado Servidor: **SQL Injection**; *Lado Cliente: **XSS – HTML Injection** (robo de cookies). Los **parámetros dinámicos** (llamados ***bind***) son una alternativa para presentar datos de la base de datos, en vez de incorporar valores dentro de la sentencia SQL, se incorporan indicadores de posiciones (?, :name, @name) afectando al contenido a un solo parámetro indicado y no a toda la consulta; ***Robo de sesión** (brute force, MiTM, XSS, Phising, URLs maliciosas); es común la inyección en campos de formulario, URL, campos ocultos,.... utilizando código javascript (en el caso XSS) o código SQL con caracteres especiales (como comillas, comentarios…).

Ataques más comunes Lado Cliente: *XSS almacenado: inyección de código javascript almacenado en el servidor y entregado a múltiples usuarios; ***XSS reflejado**: Script inyectado en una solicitud, que al ser enviada al servidor este devuelve sin sanitizar los datos recibidos (ej., a través de un enlace que recibe la victima); ***DOM-Based XSS** o basado en el DOM: Código malicioso ejecutado directamente en el cliente manipulando el DOM (Document Object Model – Maninupar documentos web). Es un caso especial del reflejado. El ataque se completa solo en el navegador, sin enviar payloads al servidor. **El objetivo** principal del XSS (Cross Site Scripting) es atacar al usuario (robar cookies, redirigir,..).

Ataques más comunes de Lado Servidor: *Inyección SQL: el atacante utiliza comillas o caracteres especiales en campos de formulario/URL para alterar las consultas SQL realizadas en el servidor; ***Inyección ciega (bind SQL)**: El atacante no recibe ni datos ni un mensaje de error directo, pero puede obtener información a través de las respuestas (como verdadero/falso); ***Inyección basada en tiempo:** Se inyectan consultas SQL que provocan retrasos, y el atacante mide el tiempo de respuesta para extraer datos. Se puede considerar un subtipo de la inyección ciega; **Inyección Fuera de Banda:** Uso de canales alternativos para enviar y recibir datos; **El objetivo** en SQL injection es atacar la base de datos de la aplicación.

Tipos de autenticación: *Básica (Usuario y contraseña); ***Certificado** (certificado digital de cliente); ***Cookies** (de sesión); ***Tokens** (valor criptográfico calculado- actúa como una cookie); ***OAuth** (Open Autorization- Industria- se autoriza (no autentica) con tokens)

Vulnerabilidades Web más comunes (OWASP): 1. Pérdida de acceso; 2. Fallos Criptográficos; 3. Inyección de código; 4. Diseño inseguro; 5. Configuración defectuosa (falta de hardening, funciones innecesarias, cuentas por defecto, manejo de errores).

Almacenamiento seguro de contraseñas: ***Cifrado Seguro**: Funciones Hash (codificado (sha1,256) en vez de texto plano) y Protocolos (OpenSSL- funciones hash y sistemas de cifrado). La mejor recomendación es evitar almacenar cualquier tipo de información sensible a menos que sea necesario.

Contramedidas de seguridad: *CAPTCHAS: Evita el uso de software automatizado contra el aplicativo; ***HSTS** (HTTP Strict Transport Security Layer) intenta evitar el MiTM mediante el cifrado entre servidores y navegadores (cliente); ***CSP** (Content Security Policy) surge para dar respuesta al XSS lado cliente, mediante un estándar preaprobado que utilizan los navegadores para cargar recursos. Solo permite la ejecución de scripts en ciertas partes del aplicativo, rechazando todo lo demás (incluso inline).

Seguridad en aplicativos web: *WAF (Web Aplication Firewall) es el dispositivo más crítico en la defensa de aplicaciones en lado servidor (backend). Filtra y bloquea solicitudes de paquetes HTTP,HTTPS antes de que lleguen a servidor. La diferencia con un firewall es que también integra el tipo de datos que deben acceder a la BBDD (BigData) y controlan el comportamiento de los usuarios. Pueden identificar Bots, se puede implementar en software en la nube (AWS) o en servidor específico (Barracuda).

PRÁCTICA 3: XSS Reflejado y XSS Almacenado DVWA

SandBox: Entorno controlado y aislado para limitar el acceso y los permisos al sistema y los datos.

Tanto en iOS como en Android se disponen de unos permisos para la manipulación de datos del sistema, corriendo en su propio "Sandbox". Las aplicaciones deben estar firmadas digitalmente y verificadas para poder ser subidas a las tiendas. Dentro de los **controles de las tiendas** podemos destacar: ***Datos de usuario; *Permisos; *Actualizaciones y *Cumplimiento Normativo**.

Para ser desarrollador, se debe pasar un proceso de validación del certificado (verificación real del programador), posteriormente se genera un código por parte de la tienda que debe coincidir con el del desarrollador.

MASTG: OWASP Mobile Application Security Testing Guide; Para evitar la fuga de información y la ingeniería inversa, se ofusca el código. Una de las acciones más típicas es el Tampering, que trata de alterar el comportamiento de la aplicación manipulando el código.

La **ofuscación** es el proceso de transformar el código y los datos para hacerlos más difíciles de comprender. **ProGuard** Es un compresor, optimizador, ofuscador y preverificador de archivos de clase Java usado en Android; **SwiftShield** Es una herramienta que genera nombres irreversibles y cifrados para los objetos de su proyecto iOS.

La depuración es una forma muy efectiva de analizar el comportamiento de la aplicación en tiempo de ejecución. El Java Debug Wire Protocol (JDWP) es el protocolo utilizado para la comunicación entre un depurador y la máquina virtual Java;

CASB (Cloud Access Security Broker) proporciona monitorización sobre el acceso y uso de los servicios en la nube y uso de los dispositivos. Previene de comportamientos sospechosos y malware, alertando y registrando los eventos. Evalúa las versiones de las app (Shadow IT) y ofrecen DLP (Data Prevention Loss, mostrando toda la info en paneles de alertas o dashboard.

MDM (Mobile Device Management) conjunto de herramientas centradas en administrar y proteger los dispositivos móviles en una organización. Rastrea los dispositivos y accesos (IAM), la seguridad de las aplicaciones y de los endpoints (EDR).

Validación de datos y almacenamiento seguro: Se deben almacenar los datos encriptados para respetar normativas como RPGD, siendo la validación de los mismos mediante MFA, certificados digitales y cifrados robustos.
Ejecución de aplicaciones en SO- Móviles: En **iOS** todas las aplicaciones se ejecutan bajo el **usuario "mobile"** y directorios aleatorios; en **Android** todas las aplicaciones se ejecutan bajo un **usuario de Linux único (su)** y se asignan los datos a directorios privados y con permisos restringidos.

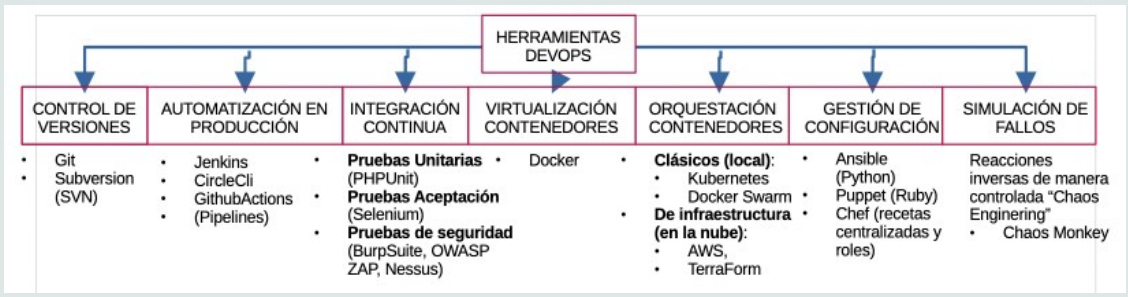
Puesta en Producción Segura (DevOpsSec): Metodología que engloba un conjunto de prácticas que engloban el desarrollo de software (Devs) y las operaciones de tecnología de la información (TI)(Ops) con procesos seguros de diseño (Sec). El concepto se basa en la seguridad desde el diseño de las aplicaciones.

DevOps es una metodología de creación, entrega y mejora continuas de software, mejorando la calidad del mismo y manteniéndose actualizado a nuevos cambios por parte del cliente. La clave es la automatización de las fases para lograr una entrega continua y eficiente.

Fases DevOps: PLANIFICACIÓN → CODIFICACIÓN → CONSTRUCCIÓN → PRUEBA → DESPLIEGUE → MANTENIMIENTO → MONITORIZACIÓN. Esta basado en la cultura colaborativa y se emplean herramientas de automatización de la construcción como Jenkins, que mantiene el control de versiones (git), ayuda a automatizar pruebas con Selenium y a la integración de nuevos módulos al programa en desarrollo antes de implementarlos al servidor en producción.

Desarrollo Ágil: Metodología cuyo principio es adaptarse al cambio ágilmente, mediante la entrega frecuente, satisfacción del cliente, cultura colaborativa en el desarrollo y la entrega, comunicación directa, reflexión continua para mejorar. Derivado del desarrollo ágil surgen los SCRUMS que son un conjunto de principios para crear productos cortos que se adaptan fácilmente a los cambios. Los principios para la mejora continua son los mismos: PLANIFICAR- HACER- VERIFICAR- ACTUAR.

CI/CD: Entrega y Despliegue continuos. Se basa en el monitoreo del Control de versiones, Automatización del Despliegue, Integración continua, empleando contenedores, gestionando la configuración segura. Una VM son entornos completamente aislados que emulan SO completos (VirtualBox), mientras que los contenedores únicamente cargan las librerías necesarias de un kernel para la ejecución de una aplicación (Docker), por lo que son mucho más ligeras.



Docker,Dockerfile, Docker Compose, Pipelines, Jenkins, por corregir

Docker (docker run):crea y ejecuta un contenedor a partir de una imagen; **Dockerfile (docker build)**: archivo de texto con instrucciones (FROM, RUN, EXPOSE…) para crear una imagen docker personalizada. Permite automatizar la creación de contenedores con dependencias predefinidas; **Docker-compose.yml:** conjunto de instrucciones para coordinar la ejecución de diferentes contenedores definidos en un archivo yaml (.yml);

Docker volume: crea un directorio para la persistencia de datos del contenedor (docker run -v ~/Desktop:/etc/personalizado mysql); **Docker Pull**: descarga la imagen especificada; **Docker images**: lista las imágenes descargadas localmente; **Docker environment (-e)** asigna variables de entorno a una ruta (./ejemplo.dll:/etc/ejemplo); **Docker ps:** contenedores corriendo; **Docker exec -it (name) bash** para ejecutar terminales interactivas; **Docker logs ()** para ver los logs del contenedor en ejecución;

Borrado seguro de imágenes: Docker ps -a → docker stop ID → docker rm ID→ docker images → docker rmi -f ID;

Docker prune: Borrado completo (incluidos datos del contenedor) de TODOS los procesos involucrados: docker container prune; docker volume prune ID; docker network prune; docker images prune.

Dockerfile: ordenes en texto plano que ayudan a construir un contenedor a partir de una imagen. (build -t (name) →run (name)

```
FROM ubuntu
LABEL maintainer="admin@ejemplo.com"
ARG APP_DATO1=1
RUN apt-get update && apt-get install -y apache2
RUN mkdir /var/www/html/ejemplo
EXPOSE 80
ADD index2.html /var/www/html/
ENTRYPOINT ["/usr/sbin/apache2ctl", "-D", "FOREGROUND"]
```

Docker-compose up -d: conjunto de instrucciones para coordinar la ejecución de diferentes servicios definidos en docker-compose.yml:

```
Services:
  mysql:
    image: mysql:5.7.28
    container_name: mysql-db1
    environment:
      MYSQL_ROOT_PASSWORD: secret
    ports:
      - "33060:3306"
    volumes:
      - mysql:/var/lib/mysql

  phpmyadmin:
    image: phpmyadmin/phpmyadmin
    container_name: phpmyadminc
    depends_on:
      - mysql
    environment:
      PMA_HOST: mysql-db1
    ports:
      - "9080:80"
    restart: unless-stopped  # Comportamiento similar a --rm

volumes:
  mysql:
```

Fases de seguridad de Pipeline: *Fase de integración (protección contra modificaciones, codificación segura (validaciones de entrada), controles de acceso y dependencias seguras); ***Fase de CI (Entrega continua):** Pruebas de seguridad dinámicas (en diferentes fases de desarrollo); ***Fase CD (Despliegue continuo):** Configuraciones de entorno vulnerables, vulnerabilidades en diferentes runners.

Jenkins: utilizado para automatización CI/CD con registro y trazabilidad (éxitos/fallos). Sirve para orquestar Pipelines (como Maven) con integración de seguridad mediante plugins (Sonarqube, owasp zap). Se configura en **JenkinsFile** (Pipeline as a Code) en lenguaje Groovy; Jenkins puede incorporar “agentes Docker” que ejecutan contenedores aislados en diferentes entornos que evitan conflictos (dependencias, librerías…); Multibranch Pipeline automatiza builds por cada rama de un repositorio Git (sincroniza con el repositorio detectando cambios en cualquier rama y permite probar código en etapas tempranas del desarrollo).

ANÁLISIS FORENSE · ANÁLISIS FORENSE · ANÁLISIS FORENSE · ANÁLISIS FORENSE · ANÁLISIS FORENSE · ANÁLISIS FORENSE · ANÁLISIS FORESE · ANÁLISIS FORESE · ANÁLISIS FORES

DAD · INCIDENTES · CIBERSEGURIDAD · INCIDENTES · CIBERSEGURIDAD · IN

TEMA 1: Planes de prevención y concienciación en ciberseguridad.

La Cibernética es la ciencia que estudia el flujo de la información de un sistema y como éste lo emplea para autocontrolarse. Consiste en aplicar estrategias tácticas y operativas de la seguridad clásica como **las tres reglas pragmáticas de la ciberseguridad según Ágile: *Prevención** (protegerse de lo conocido); ***Concienciación:** Alertar de lo desconocido (protocolos de alarma ante incidentes); ***Respuesta:** Prepararse para el peor caso (planes de respuesta rápida- IDS-SIEM-SOC (Security Operations Center); Otros elementos de prevención son el NAS (Network Access Storage) y el VAULT (Almacenamiento de secretos).

Decálogo básico de ciberseguridad (CCN) 10 Principios básicos de ciberseguridad: 1. Cultura en ciberseguridad (concienciación); 2. No descargar contenido o visitar links fuera de lo habitual; 3. Empleo de herramientas de seguridad (EDR, Firewall…); 4. Reducir superficie de exposición (servicios y puertos en desuso, ShadowIT); 5. Cifrado de información sensible; 6. Contraseñas robustas (2FA); 7. Borrado seguro de malware; 8. Copias de Seguridad (DPL); 9. Servicios actualizados; 10. Revisar configuraciones de seguridad periódicamente.

Cifrado simétrico: Una clave de red o "cifrado de clave secreta". Más rápida y adecuada para gran volumen de datos; **Cifrado Asimétrico:** 2 claves: una pública y una privada. Más lenta pero más segura.

La diferencia entre un **Snort y un Firewall** es que éste último únicamente se centra en reglas de acceso a la red, mientras que Snort se basa en reglas de políticas de acceso y comportamiento del usuario, pudiendo además de alertar (IDS), prevenir (IPS).

Medidas de seguridad en el puesto de trabajo (INCIBE): 1. Asegurarse la entrega al empleado de material y el dossier; 2. Indicar normativas de acceso a la red (contraseñas robustas, no apuntadas en texto plano); 3. Acuerdo de confidencialidad; 4. Acuerdo de uso de equipos (no filtrar datos); 5. Protección de documentación sensible mediante cifrado.

Plan de Formación y Concienciación en Ciberseguridad: tiene como objetivo asegurar la **cultura en ciberseguridad** y que los empleados conocen, entienden y cumplen las normas y las medidas de protección advirtiendo de los riesgos por parte de la Dirección. El mal uso de la información tiene consecuencias sobretodo para el delegado RPGD.

Los Controles para revisar la política de privacidad y cumplimiento constan de 2 niveles: *Básicos: El esfuerzo y los recursos necesarios son asumibles que previenen ataques más comunes; *Avanzados: El esfuerzo y los recursos necesarios son considerables y necesitan configuraciones más complejas. Los controles podrán ser sobre: Procesos, Personas y Tecnología. Una de las herramientas empleadas para la concienciación es el Kit de ciberseguridad del INCIBE que no requiere conocimientos previos para su implantación.

El uso de **Auditorías** es necesario para conocer el nivel de seguridad (madurez en ciberseguridad) de la empresa, que deberán realizarse por personal cualificado y especializado con el objetivo de obtener evidencias para determinar el nivel de cumplimiento en materia de seguridad y el nivel de seguridad de la empresa.

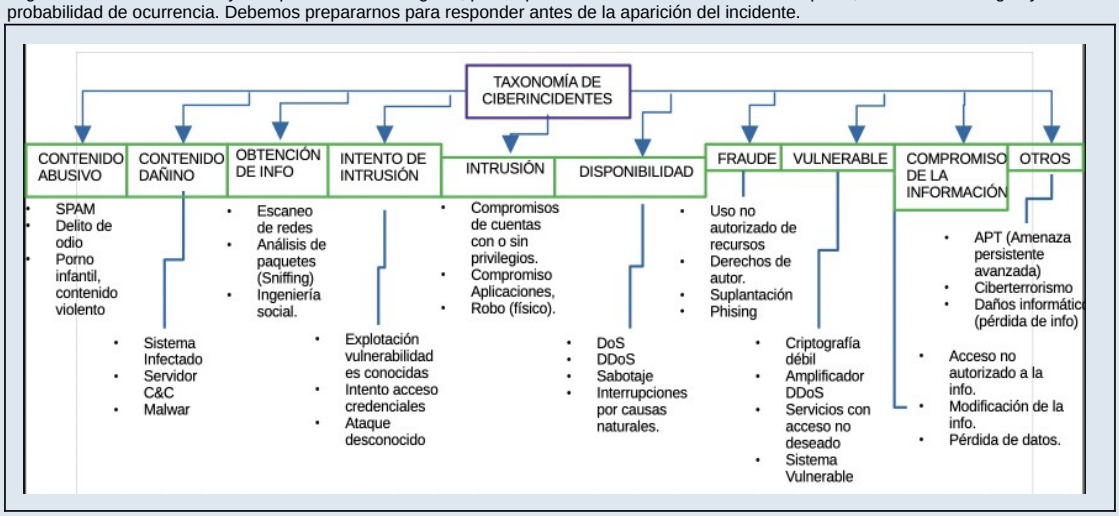
Consideraciones de una Auditoría: *Listar activos esenciales (BBDD, Ficheros…); *Comprobar medidas de seguridad para cada activo listado (EDR, Compliance, Accesos…); *Establecer procedimientos de autoría (Test de penetración, de red, legal…); el objetivo es identificar riesgos, evaluarlos y establecer contramedidas necesarias. Todo el proceso debe incluirse en un ciclo de mejora continua que se repita periódicamente. Especial atención al cumplimiento del SGSI (Seguridad de la información 27001 y RGPD).

Modelos de madurez: *NIST; ISO 27001; Esquemas de **mejora continua**: Cliclo Deming, LEAN.

PRÁCTICA 1: Auditoría Interna. Requisitos (Fase de reconocimiento, Fase de Análisis, Cierre de Auditoría). Topología de Red (Estrella). Listado de activos, Definición de pruebas (red, web…), Recomendaciones, Mejora continua (NIST), cierre auditoría.

TEMA 2: Auditoria de incidentes de Ciberseguridad

Un Incidente de ciberseguridad es uno o varios eventos inesperados o no deseados que tiene una alta probabilidad de comprometer la seguridad de la información y las operaciones del negocio, por lo que se hace necesario analizar su impacto, determinar su origen y probabilidad de ocurrencia. Debemos prepararnos para responder antes de la aparición del incidente.



La seguridad física se refiere al conjunto de medidas que protegen los equipos y documentación ante pérdidas, robos o accesos no autorizados, regulada por la norma ISO 27001. Distingue entre Áreas Seguras y Seguridad de los Equipos.

OSINT (Open Source Intelligence) hace referencia al recopilado de información a partir de fuentes abiertas. Existen herramientas que ofrecen mucha información que se debe filtrar. Se emplean técnicas como Google Dorking, buscadores de dispositivos (shodan), rastreadores de iP…Las herramientas por excelencia son Maltego y Palantir, buscando relaciones entre personas y datos, empresas, con info pública.

La gestión de incidentes se basa en disponer de un plan de respuesta rápida mediante IDS e IPS, además del análisis de logs de SIEM y las configuraciones del seguridad.

PILAR y Contramedidas:

Priorización de Activos: *Esenciales de la Información; *Esenciales del servicio; *Equipamiento informático; *Redes de comunicación.

Solo prioriza elementos esenciales y de seguridad perimetral. La clasificación de los dominios de seguridad debe ser **[essential&arch].**

Como parte positiva, ofrece Riesgos potenciales, actuales, objetivo y Pilar (conocidos) en base a amenazas indicadas, generando reportes de Salvaguardas, mejoras y recomendaciones para cumplir con los estándares de seguridad del ENS, representando estos riesgos y amenazas en diferentes tipos de gráficos.

Plan Director: Las salvaguardas, mejoras y recomendaciones forman la parte más activa para el desarrollo del plan de mejora continua.

PRÁCTICA 2: PILAR- Análisis de riesgos. Priorización de Activos, Dominios de seguridad (VLANS), Clasificación según su prioridad, Valoración de Activos, Factores Agravantes y atenuantes, Amenazas, Salvaguardas (ENS-Auto), Mejoras (Auto), Riesgos (Potenciales, Actuales, Objetivo -Auto), Gráficos, Plan director.

TEMA 3: Investigación de los incidentes de ciberseguridad

La gestión de incidentes consiste en la detección, notificación, evaluación, respuesta, tratamiento y aprendizaje de los incidentes de seguridad. Es un conjunto ordenado de acciones enfocadas a prevenir ciberincidentes y en caso de ocurrencia, restaurar las operaciones lo antes posible.

Fases de proceso de investigación: *Preparación (formación y concienciación); *Contención (y notificación); *Mitigación (CSIRT); *Recuperación; *Actuaciones-post incidente (lecciones aprendidas, write-up, playbook).

El procedimiento de Notificación a CISRT son 3 fases: *Apertura (análisis); ***Priorización** (peligrosidad e impacto); ***Resolución** (comunicación a partes implicadas).

Principios para la recolección de evidencias (**RFC-3227**): *Capturar imagen del sistema precisa; *Notas detalladas (**timeline**); *Evitar alteraciones o modificaciones; *Preservar la info correctamente;* Adquirir según el orden de volatilidad (registros cpu, ram, discos..);

Notificación de incidentes: **CSIRT:** Equipo de respuesta ante Incidentes: **CCN-CERT** (OSE, PSD- Sector público- Herramienta LUCIA), **INCIBE-CERT** (Para sector privado- Ventanilla Única); **ESPDEF-CERT** (Coopera con INCIBE en la defensa nacional). La comunicación se regula desde un **Punto de Contacto Único** y coordinador técnico. Para notificar se utiliza el criterio de Nivel de peligrosidad independientemente de que después se clasifique con un Nivel de Impacto que haga necesaria la comunicación a un CSIRT. Los incidentes que coincidan con más de una taxonomía serán catalogador con la de peligrosidad superior, pudiendo haber 5 niveles de peligrosidad de BAJO a CRÍTICO. El impacto se evalúa por las consecuencias, no por el tipo de ataque.

Volatility: Playbook: Write-up

"python3 vol.py -f (captura) -o (salida de registros) _argumento"

"EX: python3 vol.py -f captura.dmp -o ~/Desktop windows.info.Info"

Playbook: Plan de respuesta rápido ante un incidente concreto, incluye roles, responsabilidades y herramientas a utilizar.

Write-up: Documento que resume las Lecciones aprendidas sobre el ataque, breve explicación, contextualización, plan de respuesta y recomendaciones ante posibles ocurrencias futuras.

PRÁCTICA 3: Análisis de logs con Autopsy. Adquisición de RAM con Magnet RAM Capture y Captura de imagen con FTK Imager. Extracción de imagen Pendrive con GuyManger y análisis con Volatility.

TEMA 4: Implantación de medidas de ciberseguridad; TEMA 5: Detección y Documentación de ciberincidentes.

Se deberán implementar **medidas de seguridad** para la prevención de incidentes compuestas por procedimientos, capacidades, flujos de tomas de decisión y mecanismos de restablecimiento de los servicios afectados.

Procedimientos de Actuación ante Incidentes: *Determinar las causas y síntomas del incidente; *Identificar y eliminar software involucrado; *Recuperación de Copias de seguridad; *Servicios involucrados en el ataque; *Informe de ciberincidente; *Lecciones aprendidas (write-up, playbook).

Ciberresiliencia es la capacidad de resistir, proteger y defender el uso del ciberespacio ante atacantes. Generalmente existen carencias para resistir ataques debido a: *Falta de medidas técnicas; *Falta de formación; *Falta de pruebas y planes. Existen varios niveles de ciberresiliencia: INEXISTENTE → INICIAL (identificación de requisitos) → REPETIBLE (aplicación de requisitos) -» DEFINIDO (Documentado el proceso) -» GESTIONADO (actualizan y verifican requisitos) -» OPTIMIZADO (acciones de mejora); la ciberresiliencia es reactiva y no solo debe ser puntual, sino que debe ser un proceso de formación y prevención continua. El modelo de evaluación de indicadores a seguir es IDENTIFICACIÓN → PROTECCIÓN → DETECCIÓN → RESPUESTA → RECUPERACIÓN.

Estrategia de contención de ciberincidentes: establecer flujos de toma de decisiones y escalado interno. Los criterios para la toma de decisiones deben tener en cuenta toda la información posible, la iniciativa más popular es realizar Offensive Security, por lo tanto se debe conjugar todas las amenazas y sus medidas con las particularidades de la organización para crear flujos coherentes de decisión en ciberseguridad. **PREPARACIÓN -» IDENTIFICACIÓN -» CONTENCIÓN -» MITIGACIÓN -» RECUPERACIÓN -» CIERRE**.

La Documentación de los incidentes es esencial para elaborar planes de respuesta; de debe documentar su causa, su coste (impacto) y las medidas adoptadas para resolverlo y prevenir futuros incidentes (lecciones aprendidas). Las **lecciones aprendidas** se encarna en la **filosofía Lean**, documentando el problema para poder responder de forma temprana en un futuro.

La cuarentena es el período de tiempo definido para adoptar medidas especiales de monitorización, lo que propicia un seguimiento de incidentes para evitar su reproducción futura, para lo que es necesario un SOC, a través de logs (SIEM) y alertas (IDS).

Niveles de impacto para notificación: Al igual que los niveles de peligrosidad, corresponde con: *Bajos; *Medios; *Altos; *Muy Altos; *Críticos. Debe comunicarse a través de su sistema o mediante una plantilla de notificación (no oficial). Podemos recibir notificaciones Iniciales, Intermedias y Finales, mientras que en los Estados un incidente debe ser: Cerrados y Abiertos (con comentarios o sin resolución).

Notificación interna: Es el conjunto de mecanismos, procedimientos, reglas y sistemas de registro y notificación propios de la organización privada, con el objetivo de protocolizar el registro de datos y notificarlo mediante el sistema Adhoc (intercambio de información) que se basa en el registro del SIEM.

Procedimiento de Notificación: Se envía un correo (plantilla) o ticket desde la plataforma. El CSIRT Gestiona el incidente enviando a cada organismo de notificación: ESPDEF-CERT Defensa nacional; CNPIC infraestructuras críticas; AEPD si afecta a RPGD; CCN-CERT para accesos permanentes bajo el ENS (Admin. Pública) → El CSIRT se comunica para obtener más detalles e iniciar la investigación.

PRÁCTICA 4: Plan de Actuación ante Incidentes. Preparación, Identificación (personas contacto), contención, Mitigación (playbooks), Mejora continua (Write-up), Notificación de resultados; TEMA 5: Notificación Incidentes, Clasificación Taxonomía, Plantilla de notificación, Respuesta CSIRT y Cierre Notificación.

Prototipo de un SOC: Alerta IDS (Snort-logs/Siem) -» Procesamiento (Logstash) -» Almacenamiento (Elasticsearch) -» Visualización Kibana.

Ejemplo de regla SNORT: drop tcp 192.168.1.52 any -> $HOME_NET any (msg:"ATAQUE SSH";sid:3000003); alert icmp any any -> $HOME_NET any (msg:"¡Trafico ICMP!"; sid:3000001;); alert tcp any any -> any 22 (msg:"Acceso SSH"; sid:3000002;); **Header**: Acción + protocolo + Ip origen + puerto origen → destino + puerto destino; **Tailer:** Mensaje + opciones.

Configuración de Snort: /etc/snort.conf o snort.lua; **Reglas:** /etc/snort/rules/local.rules;

Opciones más comunes de snort Drop; Reject; Accept. Alert

NIVEL	CAPA	FUNCIÓN	DATOS TÉCNICOS Y PROTOCOLOS DE COMUNICACIONES
7	Aplicación	Del Proceso de Red a la Aplicación	DNS, WWW/HTTP, P2P, EMAIL/POP, SMTP, Telnet, FTP
6	Presentación	Representación y Cifrado de Datos	Reconocimiento de Datos: HTML, DOC, JPEG, MP3, AVI, Sockets
5	Sesión	Comunicación entre hosts	Establecimiento de Sesión en TCP, SIP, RTP, RPC-Named pipes
4	Transporte	Conexiones Extremo a Extremo y Fiabilidad	TCP, UDP, SCTP, SSL, TLS
3	Red	Determinación de la Ruta y Direccionamiento Lógico	IP, ARP, Ipsec, ICMP, IGMP, OSPF
2	Enlace de Datos	Direccionamiento Físico	Ethernet, 802.11, MAC/LLC, VALN, ATM, HDP, Fibre Channel, Frame Relay, HDLC, PPP, Q.921, Token Ring
1	Física	Medios, Señales y Transmisión Binaria	RS-232, RJ45, V.34, 100-BASE-TX, SDH, DSL, 802.11

ELK Stack: Logstash (filebeat), Elasticsearch, Kibana

Filtros Grok: Es un motor de patrones que permite **parsear** expresiones predefinidas o personalizadas. Herramienta fundamental para Logstash para filtrar los logs de datos no estructurados, como los de Snort, y convertirlos a datos organizados que pueden ser leídos por Elasticsearch y presentados en Kibana. Su objetivo es extraer la expresión y convertirla a un dato estructurado: **% {PATRÓN_PREDEFINIDO:nombre_del_campo}.** Los patrones se guardan en **/etc/logstash/patterns/**.

Secuencia de envío: Filebeat (host) -» Logstash (localhost:5044) -» Elasticsearch (localhost:9200) -» Kibana (localhost:5601).

Logstash guarda los logs de errores en /var/log/logstash/logstash-plain.log; para todos los programas de systemctl → journalctl;

Tableros Kibana: Sirven para representar los datos (index patterns) de los índices de Elasticsearch creados por Logstash. Podemos encontrar representaciones por: *Métricas (filtros, indicadores); *Gráficos de barras u *Histogramas. Diferentes visualizaciones se pueden mostrar en el mismo Dashboard.

NORMATIVAS		Módulo
ISO 37301 (ANTIGUA 19600)	Sistema de Gestión Compliance (ISO es certificable y 19600 no)	NC
ISO 31000	Sistema de Gestión de Riesgos	NC
UNE-EN 19601	Sistema de Gestión de Cumplimiento Penal (España)	NC
ISO 37001	Sistema de Gestión Antisoborno Y AntiFraude	NC
ISO 27001	Sistema de Gestión de Seguridad de la Información	NC
ISO 27002	Controles y Privacidad (amplía 27001)	NC
ISO 22301	Sistema de Gestión de Continuidad del Negocio	NC
RF-3227	Directrices para la recopilación de evidencias (INCIBE)	BRS, AFI
ISO 27037	Directrices para la recopilación y preservación de evidencias digitales Internacionalmente	
OWASP **ASVS**	Guía de Verificación de Seguridad de una Aplicación Web	PPS
OWASP MASVS	Guía de Verificación de Seguridad de una Aplicación Móvil	PPS
OWASP MASTG	Guía de Pruebas de Seguridad de App Móviles	PPS

TOP TEN OWASP
1. Pérdida de control de acceso
2. Fallos Criptográficos
3. Inyección
4. Diseño Inseguro
5. Fallos de configuración de seguridad
6. Componentes Vulnerables y desactualizados.
7. Fallos de identificación y autenticación
8. Fallos de integridad en software y datos
9. Fallos de monitorización y seguridad del acceso (logging)
10. Server-Side Request Forgery (SSRF) Peticiones a servidor.

CÁLCULO DE RIESGOS EN PILAR (Disponibilidad- Integridad- Confidencialidad)	
POTENCIAL	POTENCIAL – ACTUAL
ACTUAL	ACTUAL – OBJETIVO
OBJETIVO	OBJETIVO – PILAR
PILAR	POTENCIAL – PILAR

Identificación→ dominios de seguridad → amenazas = Mejoras → riesgos → salvaguardas → gráficos.